



Instituto Politécnico Nacional
Escuela Superior de Cómputo



Ingeniería en Sistemas Computacionales
Academia de Sistemas Distribuidos

Unidad de Aprendizaje:
Gobierno de TI | Computer Security

Práctica 2: “Sistema Operativo Windows:
Controles de Seguridad”

Luis Andrés Contla Mota

2022630540

6CV4

Profesor:

MBA. Rodrigo Ojeda Santillán

Objetivo

Que los alumnos comprendan y apliquen los controles de seguridad modernos implementados en Windows 11, adquiriendo competencias prácticas en hardening de sistemas operativos, auditoría de seguridad y defensa contra amenazas actuales. A través de la ejecución de diez laboratorios progresivos, los estudiantes dominarán tecnologías clave como Seguridad Basada en Virtualización (VBS), reglas de Reducción de Superficie de Ataque (ASR), BitLocker acelerado por hardware, Credential Guard, y herramientas de detección de amenazas nativas como Sysmon. El propósito es que los alumnos no solo identifiquen vulnerabilidades de seguridad en instalaciones estándar de Windows, sino que también implementen soluciones de hardening que alineen con estándares internacionales como CIS Benchmarks y Microsoft Security Baselines, desarrollando una comprensión integral de la postura de seguridad defensiva en entornos contemporáneos.

Introducción

Para la realización de la práctica, es importante tener en cuenta la siguiente información. La Seguridad Basada en Virtualización utiliza el hipervisor del procesador para crear un entorno de memoria completamente aislado del kernel de Windows, asumiendo que el kernel podría estar comprometido. Este contenedor virtualizado se convierte en la raíz de confianza del sistema operativo, ejecutando componentes críticos como Credential Guard, que protege credenciales contra ataques de robo (Pass-the-Hash, Pass-the-Ticket), e HVCI (Hypervisor-Protected Code Integrity), que verifica la integridad de código en tiempo de ejecución sin permitir inyección de malware a nivel kernel. Desde Windows 11 22H2, VBS está habilitado por defecto en dispositivos Enterprise que cumplen requisitos de hardware.

Las reglas de Reducción de Superficie de Ataque (ASR) implementan un control proactivo que bloquea comportamientos específicos que el malware explota comúnmente pero que aplicaciones legítimas rara vez utilizan. A diferencia del antivirus que reconoce malware mediante firmas, ASR controla técnicas de ataque como la creación de procesos secundarios desde Office o inyección de código. Estas reglas pueden configurarse en tres estados: Block (bloqueo activo), Audit (registro sin bloqueo) y Warn (advertencia). Las reglas ASR son especialmente efectivas contra ransomware, exploits de aplicaciones y técnicas de persistencia.

BitLocker es la solución de cifrado de disco completo integrada en Windows para proteger datos en reposo contra acceso físico no autorizado. A partir de Windows 11 25H2, BitLocker recibió aceleración por hardware que descarga operaciones criptográficas a motores dedicados en procesadores modernos. Esta aceleración

duplica las velocidades de lectura y escritura (de ~1,632 MB/s a ~3,746 MB/s en lectura). Las claves criptográficas se envuelven a nivel de silicio, minimizando exposición a vulnerabilidades. Este avance elimina la compensación tradicional entre cifrado y rendimiento del sistema.

A partir de febrero de 2026, Sysmon se integra nativamente en Windows 11 (Build 26200.7922+), disponible por defecto sin instalación adicional. A diferencia de eventos de Windows estándar, Sysmon captura telemetría de alta fidelidad: líneas de comandos completas (Event ID 1), conexiones de red (Event ID 3), acceso a procesos críticos como LSASS (Event ID 8), creación de archivos (Event ID 11) y manipulación de procesos (Event ID 25). Esta telemetría es crítica para detectar comportamientos sofisticados de malware y cadenas de ataque avanzadas.

El Center for Internet Security (CIS) y Microsoft mantienen marcos de referencia de hardening que definen configuraciones óptimas de seguridad. El CIS Benchmark para Windows 11 Enterprise v4.0.0 contiene cientos de recomendaciones en categorías como políticas de cuentas, registro y políticas administrativas, organizadas en perfiles de impacto: Nivel 1 (L1) proporciona seguridad práctica con mínimo impacto en usabilidad, mientras que Nivel 2 (L2) implementa controles estrictos. La herramienta HardeningKitty automatiza la auditoría contra estos benchmarks.

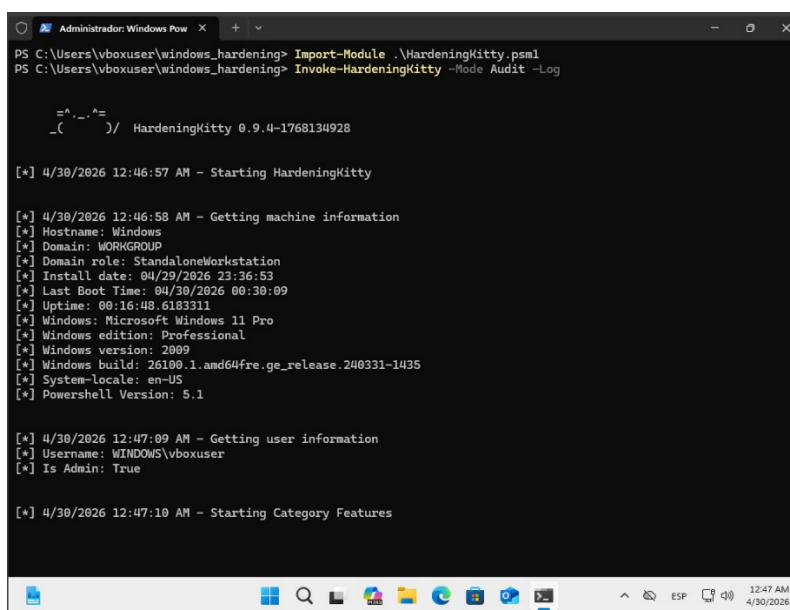
Controlled Folder Access monitorea cambios que las aplicaciones realizan en carpetas sensibles (Documentos, Escritorio, Imágenes). Solo aplicaciones en lista blanca de confianza pueden modificar archivos en estas carpetas; si una aplicación desconocida intenta escribir, el acceso se bloquea inmediatamente y se genera una alerta. Esto proporciona defensa directa contra ataques de cifrado de archivos, incluso si el ransomware logra ejecutarse en el sistema, complementando otras capas de defensa como BitLoc

Desarrollo

Laboratorio 1 - Auditoría de Security Baseline con HardeningKitty

Objetivo: Auditar la máquina contra el Microsoft Security Baseline usando HardeningKitty y remediar configuraciones críticas.

Paso 1. Se clona el repositorio de HardeningKitty



```
PS C:\Users\vboxuser\windows_hardening> Import-Module .\HardeningKitty.psml
PS C:\Users\vboxuser\windows_hardening> Invoke-HardeningKitty -Mode Audit -Log

==*.==
_(_)/ HardeningKitty 0.9.4-1768134928

[*] 4/30/2026 12:46:57 AM - Starting HardeningKitty

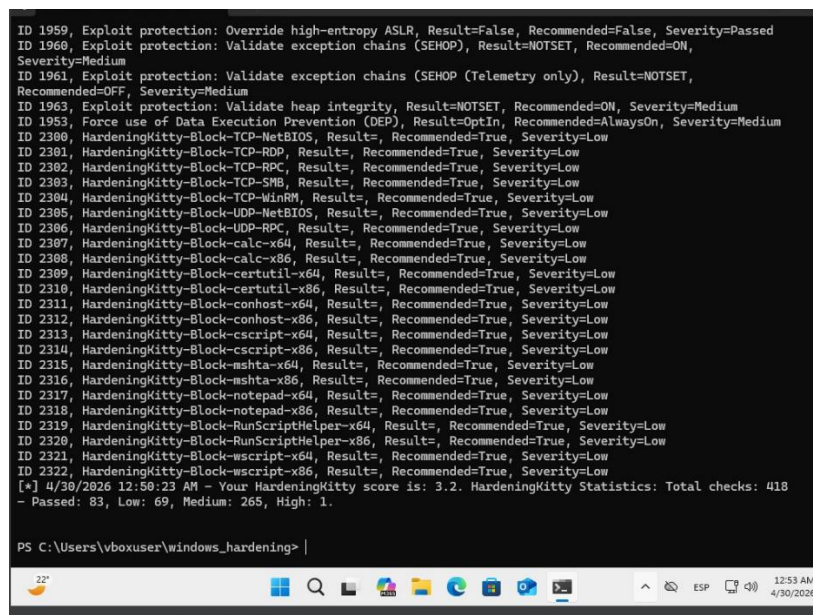
[*] 4/30/2026 12:46:58 AM - Getting machine information
[*] Hostname: Windows
[*] Domain: WORKGROUP
[*] Domain role: StandaloneWorkstation
[*] Install date: 04/29/2026 23:36:53
[*] Last Boot Time: 04/30/2026 00:30:09
[*] Uptime: 00:16:48.6183311
[*] Windows: Microsoft Windows 11 Pro
[*] Windows edition: Professional
[*] Windows version: 20H9
[*] Windows build: 26100.1.amd64fre.ge_release.240331-1435
[*] System-locale: en-US
[*] Powershell Version: 5.1

[*] 4/30/2026 12:47:09 AM - Getting user information
[*] Username: WINDOWS\vboxuser
[*] Is Admin: True

[*] 4/30/2026 12:47:10 AM - Starting Category Features
```

Ilustración 1 HardeningKitty clonado

Paso 2. Entrar al directorio y ejecutar la auditoría inicial

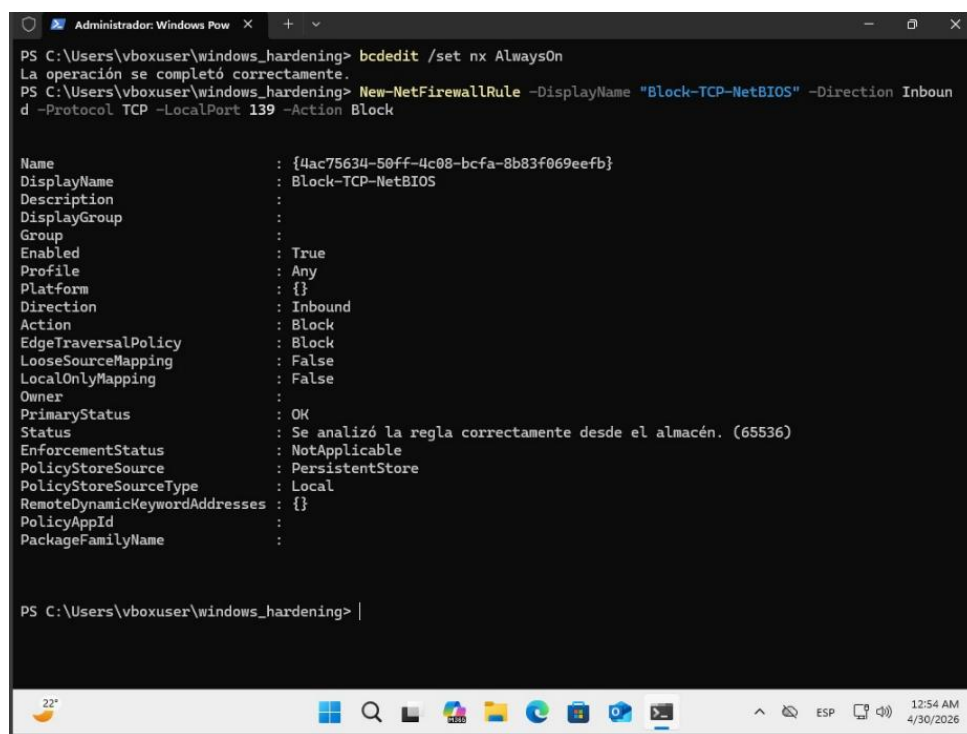


```
ID 1959, Exploit protection: Override high-entropy ASLR, Result=False, Recommended=False, Severity=Passed
ID 1960, Exploit protection: Validate exception chains (SEHOP), Result=NOTSET, Recommended=ON, Severity=Medium
ID 1961, Exploit protection: Validate exception chains (SEHOP (Telemetry only), Result=NOTSET, Recommended=OFF, Severity=Medium
ID 1963, Exploit protection: Validate heap integrity, Result=NOTSET, Recommended=ON, Severity=Medium
ID 1963, Force use of Data Execution Prevention (DEP), Result=OptIn, Recommended=AlwaysOn, Severity=Medium
ID 2300, HardeningKitty-Block-TCP-NetBIOS, Result=, Recommended=True, Severity=Low
ID 2301, HardeningKitty-Block-TCP-RDP, Result=, Recommended=True, Severity=Low
ID 2302, HardeningKitty-Block-TCP-RPC, Result=, Recommended=True, Severity=Low
ID 2303, HardeningKitty-Block-TCP-SMB, Result=, Recommended=True, Severity=Low
ID 2304, HardeningKitty-Block-TCP-WinRM, Result=, Recommended=True, Severity=Low
ID 2305, HardeningKitty-Block-UDP-NetBIOS, Result=, Recommended=True, Severity=Low
ID 2306, HardeningKitty-Block-UDP-RPC, Result=, Recommended=True, Severity=Low
ID 2307, HardeningKitty-Block-calc-x64, Result=, Recommended=True, Severity=Low
ID 2308, HardeningKitty-Block-calc-x86, Result=, Recommended=True, Severity=Low
ID 2309, HardeningKitty-Block-certutil-x64, Result=, Recommended=True, Severity=Low
ID 2310, HardeningKitty-Block-certutil-x86, Result=, Recommended=True, Severity=Low
ID 2311, HardeningKitty-Block-conhost-x64, Result=, Recommended=True, Severity=Low
ID 2312, HardeningKitty-Block-conhost-x86, Result=, Recommended=True, Severity=Low
ID 2313, HardeningKitty-Block-cscript-x64, Result=, Recommended=True, Severity=Low
ID 2314, HardeningKitty-Block-cscript-x86, Result=, Recommended=True, Severity=Low
ID 2315, HardeningKitty-Block-mshta-x64, Result=, Recommended=True, Severity=Low
ID 2316, HardeningKitty-Block-mshta-x86, Result=, Recommended=True, Severity=Low
ID 2317, HardeningKitty-Block-notepad-x64, Result=, Recommended=True, Severity=Low
ID 2318, HardeningKitty-Block-notepad-x86, Result=, Recommended=True, Severity=Low
ID 2319, HardeningKitty-Block-RunScriptHelper-x64, Result=, Recommended=True, Severity=Low
ID 2320, HardeningKitty-Block-RunScriptHelper-x86, Result=, Recommended=True, Severity=Low
ID 2321, HardeningKitty-Block-wscript-x64, Result=, Recommended=True, Severity=Low
ID 2322, HardeningKitty-Block-wscript-x86, Result=, Recommended=True, Severity=Low
[*] 4/30/2026 12:50:23 AM - Your HardeningKitty score is: 3.2. HardeningKitty Statistics: Total checks: 418
- Passed: 83, Low: 69, Medium: 265, High: 1.

PS C:\Users\vboxuser\windows_hardening> |
```

Ilustración 2 Auditoría inicial

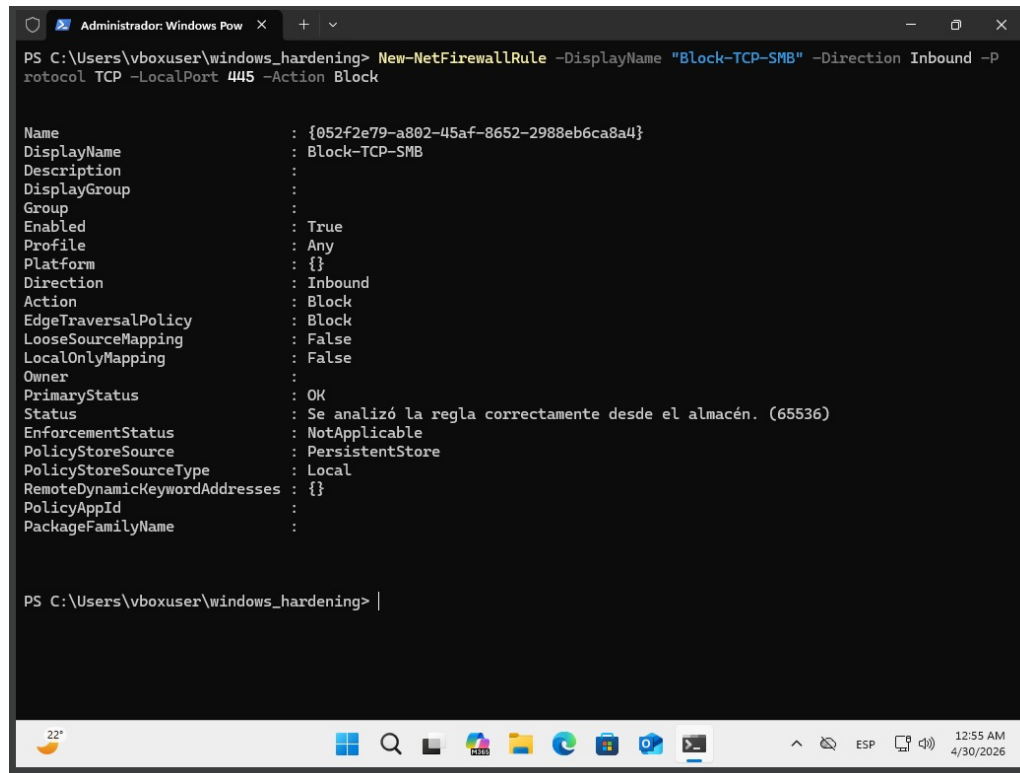
Paso 3: Realizar correcciones



```
PS C:\Users\vboxuser\windows_hardening> bcdedit /set nx AlwaysOn
La operación se completó correctamente.
PS C:\Users\vboxuser\windows_hardening> New-NetFirewallRule -DisplayName "Block-TCP-NetBIOS" -Direction Inbound -Protocol TCP -LocalPort 139 -Action Block

Name                           : {4ac75634-50ff-4c08-bcfa-8b83f069eefb}
DisplayName                     : Block-TCP-NetBIOS
Description                     :
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                       : {}
Direction                      : Inbound
Action                         : Block
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping                : False
Owner                           :
PrimaryStatus                   : OK
Status                         : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus               : NotApplicable
PolicyStoreSource               : PersistentStore
PolicyStoreSourceType           : Local
RemoteDynamicKeywordAddresses  : {}
PolicyAppId                     :
PackageFamilyName               :
```

Ilustración 3 Bloquear NetBIOS por TCP (Firewall) y Forzar DEP en AlwaysOn



```
PS C:\Users\vboxuser\windows_hardening> New-NetFirewallRule -DisplayName "Block-TCP-SMB" -Direction Inbound -Protocol TCP -LocalPort 445 -Action Block

Name                           : {052f2e79-a802-45af-8652-2988eb6ca8a4}
DisplayName                     : Block-TCP-SMB
Description                     :
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                       : {}
Direction                      : Inbound
Action                         : Block
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping                : False
Owner                           :
PrimaryStatus                   : OK
Status                         : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus               : NotApplicable
PolicyStoreSource               : PersistentStore
PolicyStoreSourceType           : Local
RemoteDynamicKeywordAddresses  : {}
PolicyAppId                     :
PackageFamilyName               :
```

Ilustración 4 Bloquear smb por tcp

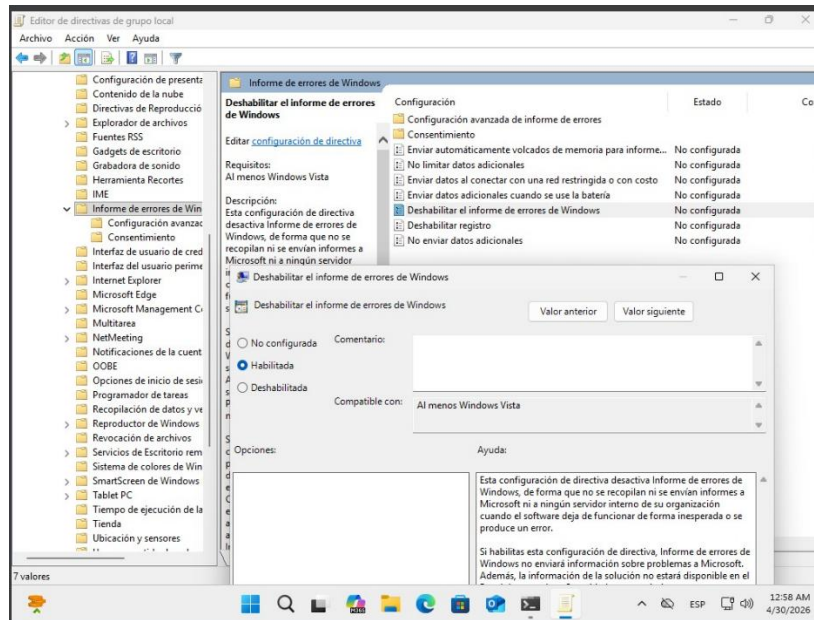


Ilustración 5 Deshabilitar Windows Error Reporting

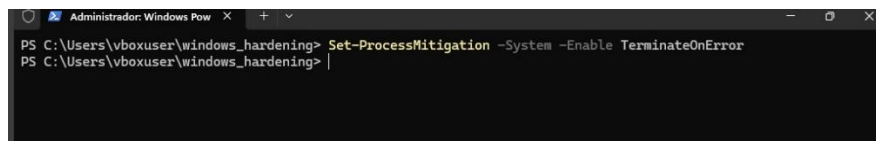


Ilustración 6 Validate heap integrity (Exploit Protection)

Paso 4: Reauditar sistema

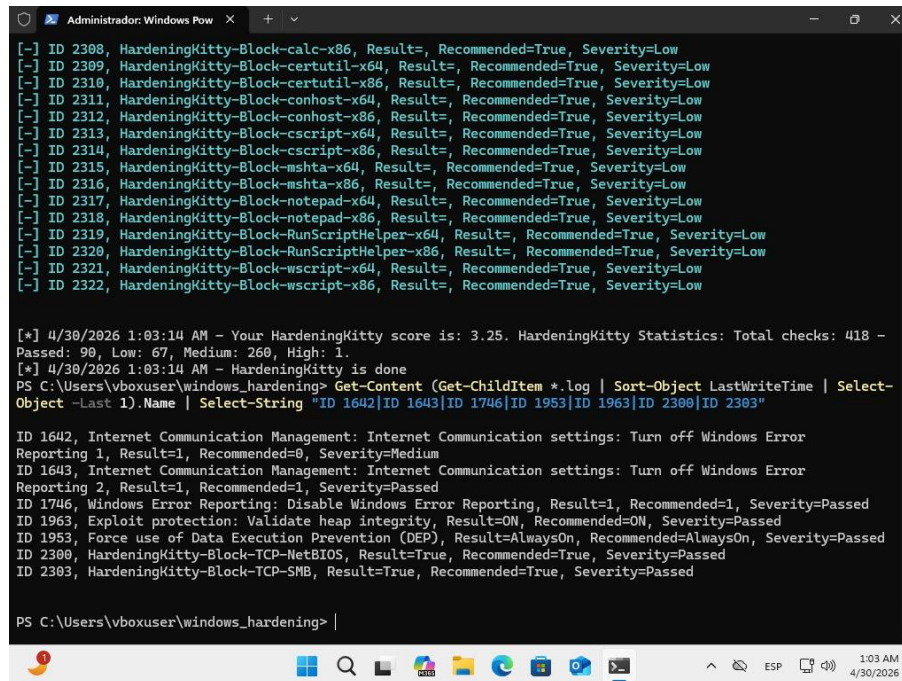


Ilustración 7 Confirmación de correcciones

Laboratorio 2 - Configuración de Reglas ASR (Attack Surface Reduction)

Objetivo: Habilitar reglas ASR en modo Audit, generar eventos simulados y documentar comportamientos bloqueados.

Paso 1. Verificar que Defender esté activo

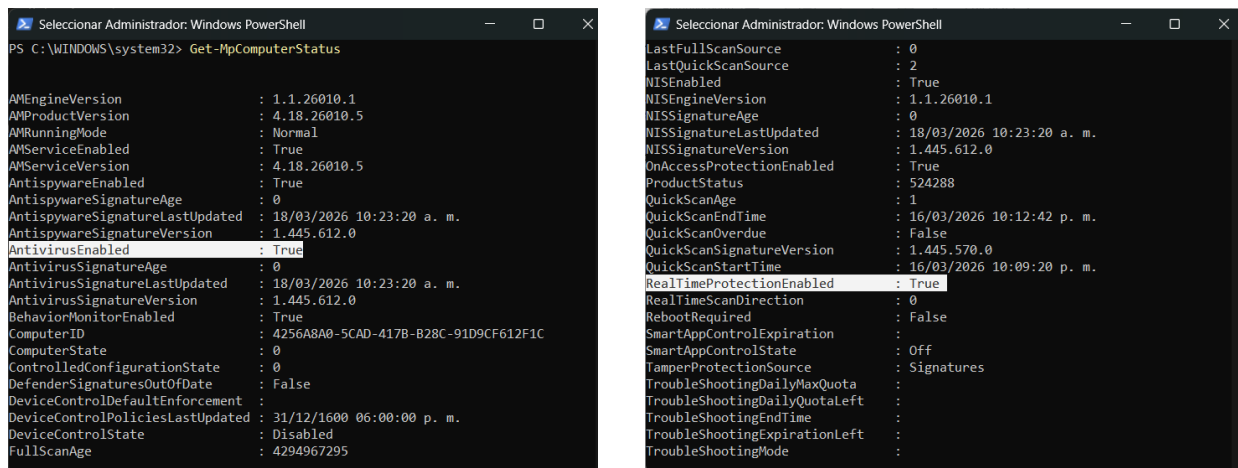


Ilustración 8 e Ilustración 9 Verificación de `AntivirusEnabled` y `RealTimeProtectionEnabled`

Paso 2. Habilitar la primera, segunda y tercera regla ASR en modo Audit y después verificamos si las reglas en efecto están habilitadas

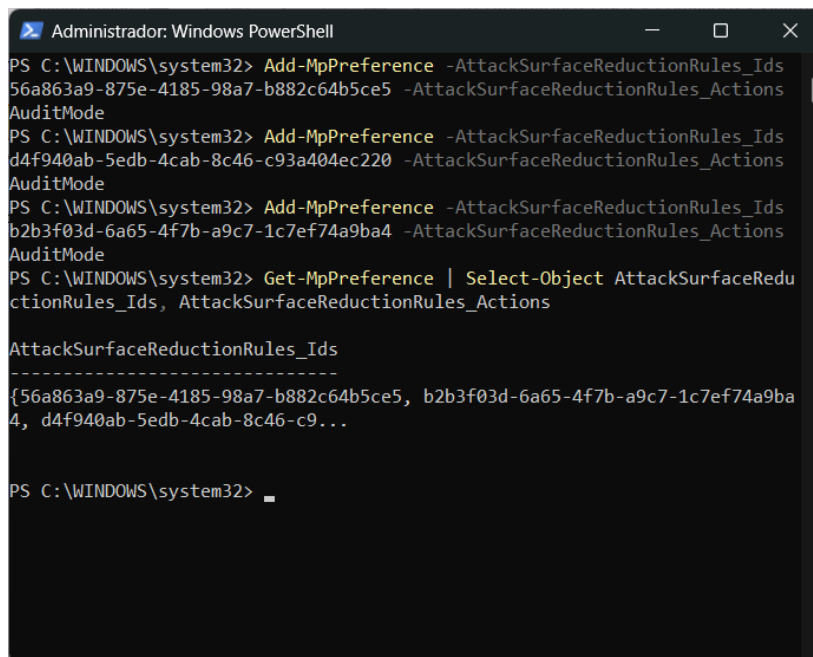


Ilustración 10 Habilitación de reglas y verificación

Paso 3. Generar un evento simulado (Lo hacemos con LSASS)


```

Windows PowerShell
PS C:\WINDOWS\System32> Get-Process lsass

Handles  NPM(K)  PM(K)  WS(K)  CPU(s)  Id  SI ProcessName
-----  -
2426     31     16212  26172         1488  0  lsass

PS C:\WINDOWS\System32>

```

Ilustración 11 Evento LSASS generado

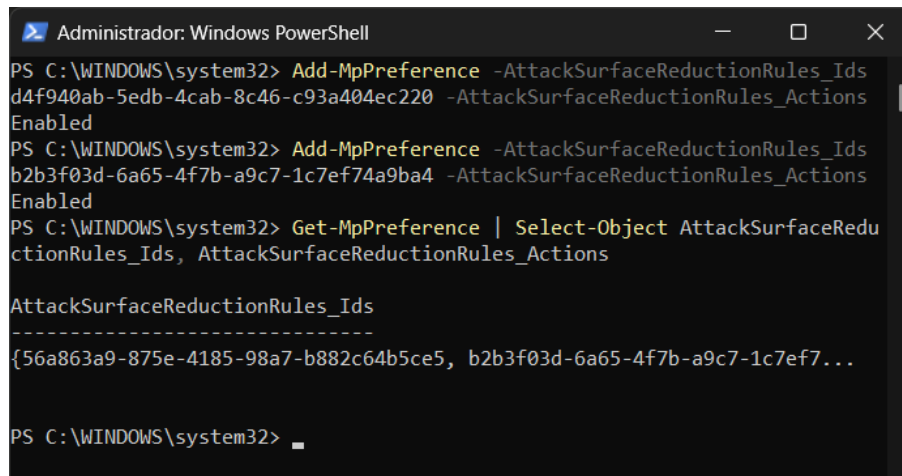
Paso 4. Revisar los eventos en Event Viewer.

En este caso al revisar Event Viewer, no se encontraron eventos con ID 1122 porque las acciones de prueba ejecutadas (comando legítimo de PowerShell) no activaron las reglas ASR. Estas reglas están diseñadas específicamente para detectar técnicas de ataque sofisticadas como inyección de código, ejecución de macros maliciosas desde Office, o acceso anómalo a procesos críticos. La ausencia de eventos confirma que el sistema funcionó correctamente sin falsas alarmas contra actividades normales.

Operational Número de eventos: 3,990				
Nivel	Fecha y hora	Origen	Id. del even...	Categoría d...
Información	09/03/2026 11:12:54 a. m.	Windows D...	1013	Ninguno
Advertencia	03/03/2026 11:26:38 a. m.	Windows D...	1116	Ninguno
Advertencia	03/03/2026 11:26:39 a. m.	Windows D...	1116	Ninguno
Advertencia	03/03/2026 11:26:40 a. m.	Windows D...	1116	Ninguno
Advertencia	03/03/2026 11:26:41 a. m.	Windows D...	1116	Ninguno
Advertencia	03/03/2026 11:26:36 a. m.	Windows D...	1116	Ninguno
Advertencia	03/03/2026 11:26:42 a. m.	Windows D...	1116	Ninguno
Advertencia	03/03/2026 11:26:34 a. m.	Windows D...	1116	Ninguno
Información	03/03/2026 11:27:16 a. m.	Windows D...	1117	Ninguno
Información	26/09/2025 03:53:48 p. m.	Windows D...	1150	Ninguno
Información	14/10/2025 04:03:07 p. m.	Windows D...	1150	Ninguno
Información	09/12/2025 11:23:57 a. m.	Windows D...	1150	Ninguno
Información	09/12/2025 10:40:17 p. m.	Windows D...	1150	Ninguno
Información	08/01/2026 11:14:22 p. m.	Windows D...	1150	Ninguno
Información	04/02/2026 08:29:43 p. m.	Windows D...	1150	Ninguno

Ilustración 12 Ventana de Visor de Eventos

Paso 5. Cambiar las reglas a modo Block



```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> Add-MpPreference -AttackSurfaceReductionRules_Ids d4f940ab-5edb-4cab-8c46-c93a404ec220 -AttackSurfaceReductionRules_Actions Enabled
PS C:\WINDOWS\system32> Add-MpPreference -AttackSurfaceReductionRules_Ids b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4 -AttackSurfaceReductionRules_Actions Enabled
PS C:\WINDOWS\system32> Get-MpPreference | Select-Object AttackSurfaceReductionRules_Ids, AttackSurfaceReductionRules_Actions

AttackSurfaceReductionRules_Ids
-----
{56a863a9-875e-4185-98a7-b882c64b5ce5, b2b3f03d-6a65-4f7b-a9c7-1c7ef7...

PS C:\WINDOWS\system32>
```

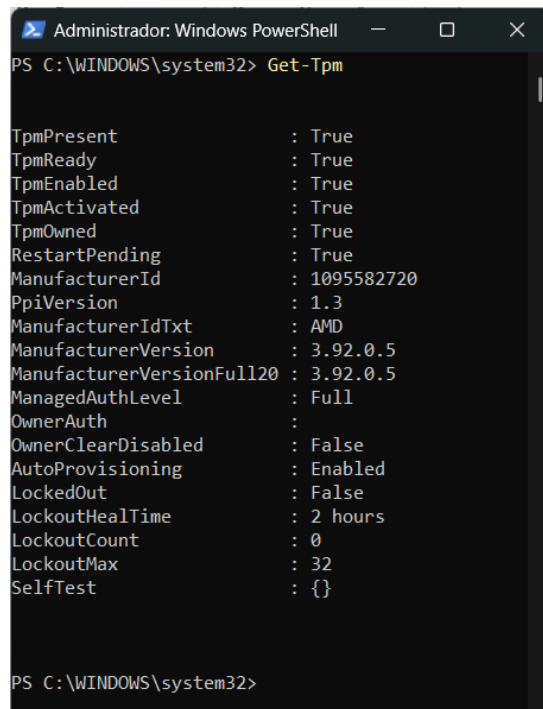
Ilustración 13 Habilitación de reglas a modo Block y verificación

Podemos concluir que las reglas Attack Surface Reduction (ASR) representan un cambio paradigmático en defensa contra malware: en lugar de buscar firmas de virus (enfoque reactivo), ASR bloquea técnicas de ataque específicas como inyección de código, macros maliciosas y acceso anómalo a procesos críticos (enfoque proactivo). Se configuraron exitosamente tres reglas ASR en modo Enabled, demostrando que Microsoft Defender ha evolucionado de un antivirus tradicional a una plataforma de defensa basada en comportamiento, capaz de prevenir ataques sofisticados antes de que causen daño.

Laboratorio 3 - Cifrado con BitLocker y Gestión de Claves

Objetivo: Habilitar BitLocker, gestionar claves de recuperación y explorar opciones de cifrado.

Paso 1: Verificar TPM 2.0



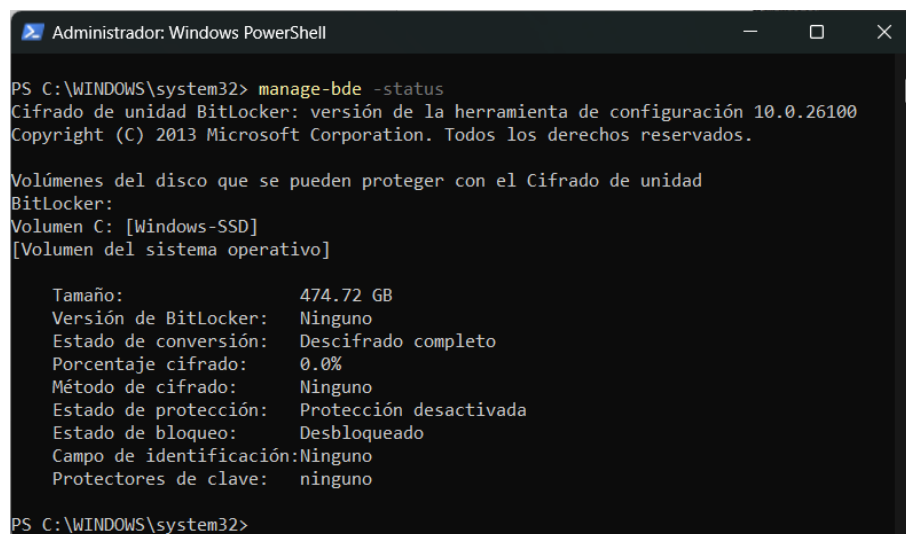
```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> Get-Tpm

TpmPresent           : True
TpmReady             : True
TpmEnabled           : True
TpmActivated         : True
TpmOwned             : True
RestartPending      : True
ManufacturerId       : 1095582720
PpiVersion           : 1.3
ManufacturerIdTxt    : AMD
ManufacturerVersion  : 3.92.0.5
ManufacturerVersionFull20 : 3.92.0.5
ManagedAuthLevel    : Full
OwnerAuth            :
OwnerClearDisabled   : False
AutoProvisioning     : Enabled
LockedOut            : False
LockoutHealTime      : 2 hours
LockoutCount         : 0
LockoutMax           : 32
SelfTest             : {}

PS C:\WINDOWS\system32>
```

Ilustración 14 Ejecución de comando Get -Tpm

Paso 2: Verificar estado de BitLocker



```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> manage-bde -status
Cifrado de unidad BitLocker: versión de la herramienta de configuración 10.0.26100
Copyright (C) 2013 Microsoft Corporation. Todos los derechos reservados.

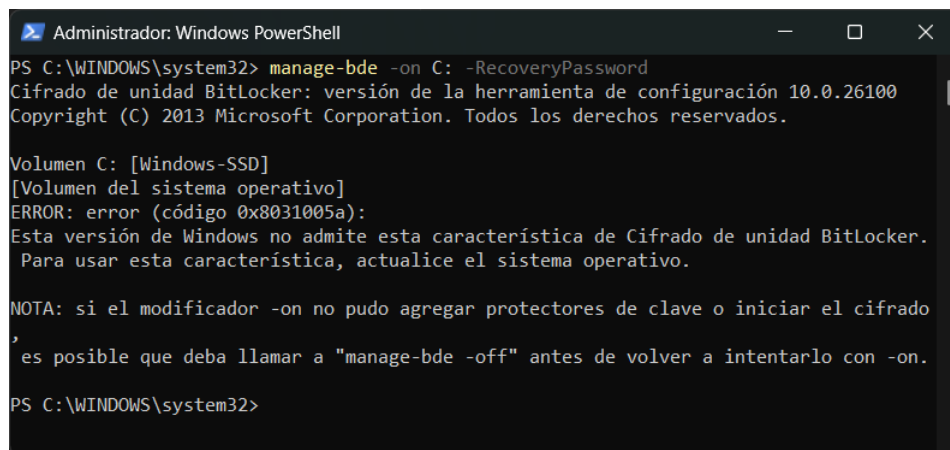
Volúmenes del disco que se pueden proteger con el Cifrado de unidad
BitLocker:
Volumen C: [Windows-SSD]
[Volumen del sistema operativo]

    Tamaño: 474.72 GB
    Versión de BitLocker: Ninguno
    Estado de conversión: Descifrado completo
    Porcentaje cifrado: 0.0%
    Método de cifrado: Ninguno
    Estado de protección: Protección desactivada
    Estado de bloqueo: Desbloqueado
    Campo de identificación:Ninguno
    Protectores de clave: ninguno

PS C:\WINDOWS\system32>
```

Ilustración 15 Comprobando estado de Bitlocker

Paso 3: Habilitar BitLocker en C

A screenshot of a Windows PowerShell window titled "Administrador: Windows PowerShell". The command prompt shows the execution of the command `manage-bde -on C: -RecoveryPassword`. The output indicates the BitLocker version is 10.0.26100 and shows copyright information. It then identifies the volume as C: [Windows-SSD] and the operating system volume. An error message follows: "ERROR: error (código 0x8031005a): Esta versión de Windows no admite esta característica de Cifrado de unidad BitLocker. Para usar esta característica, actualice el sistema operativo." A note explains that the `-on` switch might not work and suggests using `manage-bde -off` first. The prompt ends with `PS C:\WINDOWS\system32>`.

```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> manage-bde -on C: -RecoveryPassword
Cifrado de unidad BitLocker: versión de la herramienta de configuración 10.0.26100
Copyright (C) 2013 Microsoft Corporation. Todos los derechos reservados.

Volumen C: [Windows-SSD]
[Volumen del sistema operativo]
ERROR: error (código 0x8031005a):
Esta versión de Windows no admite esta característica de Cifrado de unidad BitLocker.
Para usar esta característica, actualice el sistema operativo.

NOTA: si el modificador -on no pudo agregar protectores de clave o iniciar el cifrado
, es posible que deba llamar a "manage-bde -off" antes de volver a intentarlo con -on.

PS C:\WINDOWS\system32>
```

Ilustración 16 Error al activar Bitlocker

Este laboratorio requiere Windows 11 Pro o Enterprise para acceder a BitLocker. La máquina utilizada ejecuta Windows 11 Home (versión 25H2, compilación 26200.8246), que no incluye esta funcionalidad de cifrado de disco completo. BitLocker es una característica exclusiva de ediciones Pro y Enterprise de Windows 11, diseñada para proteger datos en reposo contra acceso físico no autorizado.

Laboratorio 4 - Seguridad Basada en Virtualización (VBS y Credential Guard)

Objetivo: Verificar estado de VBS, Credential Guard e HVCI, entender protección contra Pass-the-Hash/Ticket.

Paso 1: Abrir información del sistema y comprobar Seguridad basada en virtualización (VBS)

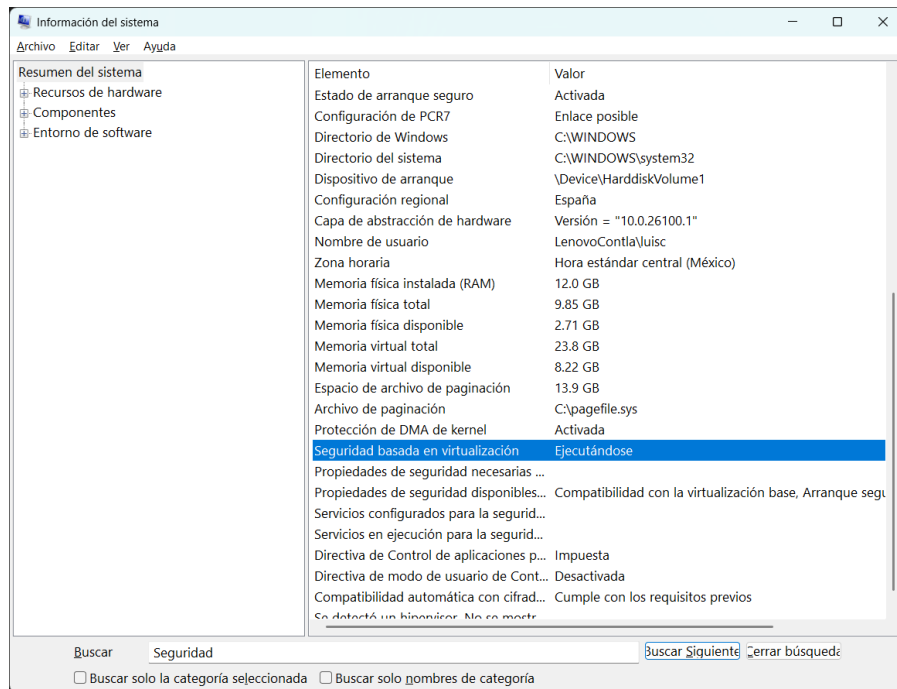


Ilustración 17 Seguridad basada en virtualización

En esta misma ventana, en la parte de hasta abajo podemos observar el mensaje que dice “Se detectó un hipervisor. No se mostrarán las características necesarias para Hyper-V.”, el cual nos indica que VBS (Virtualization-based Security) SÍ está habilitado en la máquina en la que estamos realizando la p´ractiva. El sistema detectó el hipervisor funcionando.

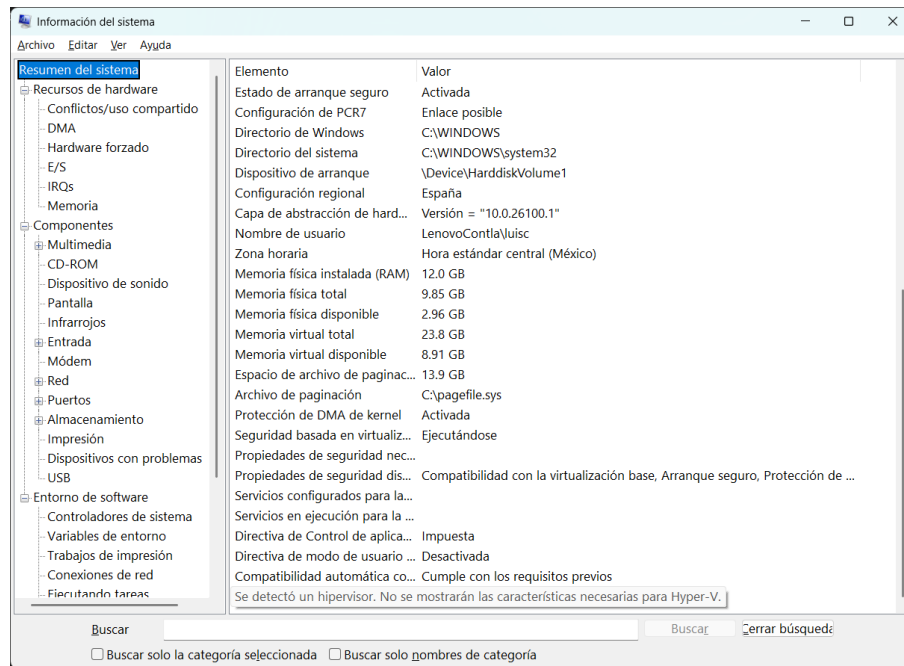
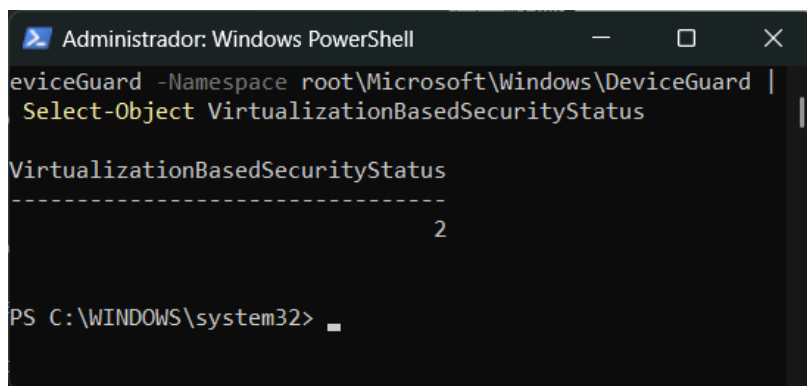


Ilustración 18 Mensaje detectando un Hipervisor

Paso 2: Verificar VBS con PowerShell

También lo podemos comprobar mediante comandos en la consola como el siguiente:



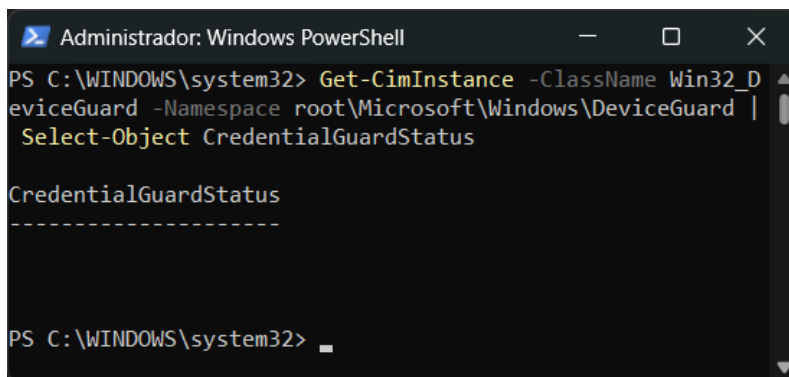
```
Administrador: Windows PowerShell
DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard |
Select-Object VirtualizationBasedSecurityStatus

VirtualizationBasedSecurityStatus
-----
2

PS C:\WINDOWS\system32>
```

Ilustración 19 Verificación de VBS en Powershell

De manera similar podemos verificar Credential Guard en consola en vez de la ventana de información:



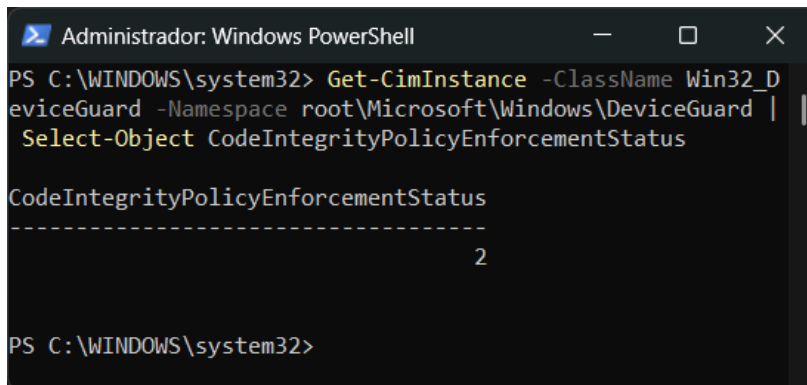
```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> Get-CimInstance -ClassName Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard |
Select-Object CredentialGuardStatus

CredentialGuardStatus
-----

PS C:\WINDOWS\system32>
```

Ilustración 20 Verificación de Credential Guard

Paso 3: Verificar Memory Integrity (HVCI)



```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> Get-CimInstance -ClassName Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard |
Select-Object CodeIntegrityPolicyEnforcementStatus

CodeIntegrityPolicyEnforcementStatus
-----
2

PS C:\WINDOWS\system32>
```

Ilustración 21 Verificación de HVCI

Con todo esto, se verificó que Virtualization-based Security (VBS) está activo con estado Running (valor 2), e HVCI (CodeIntegrityPolicyEnforcementStatus) está enforced (valor 2). Sin embargo, Credential Guard no está disponible en Windows 11 Home. VBS proporciona protección a nivel de kernel contra inyección de código, mientras que Credential Guard es una característica adicional (disponible en Pro/Enterprise) que aísla credenciales en un contenedor virtualizado. La infraestructura base de seguridad virtualizada está presente y funcional en esta máquina.

Laboratorio 5 - Windows Firewall con Seguridad Avanzada

Objetivo: Configurar firewall avanzado, crear reglas personalizadas y documentar perfiles de red.

Paso 1: Abrir Firewall Avanzado

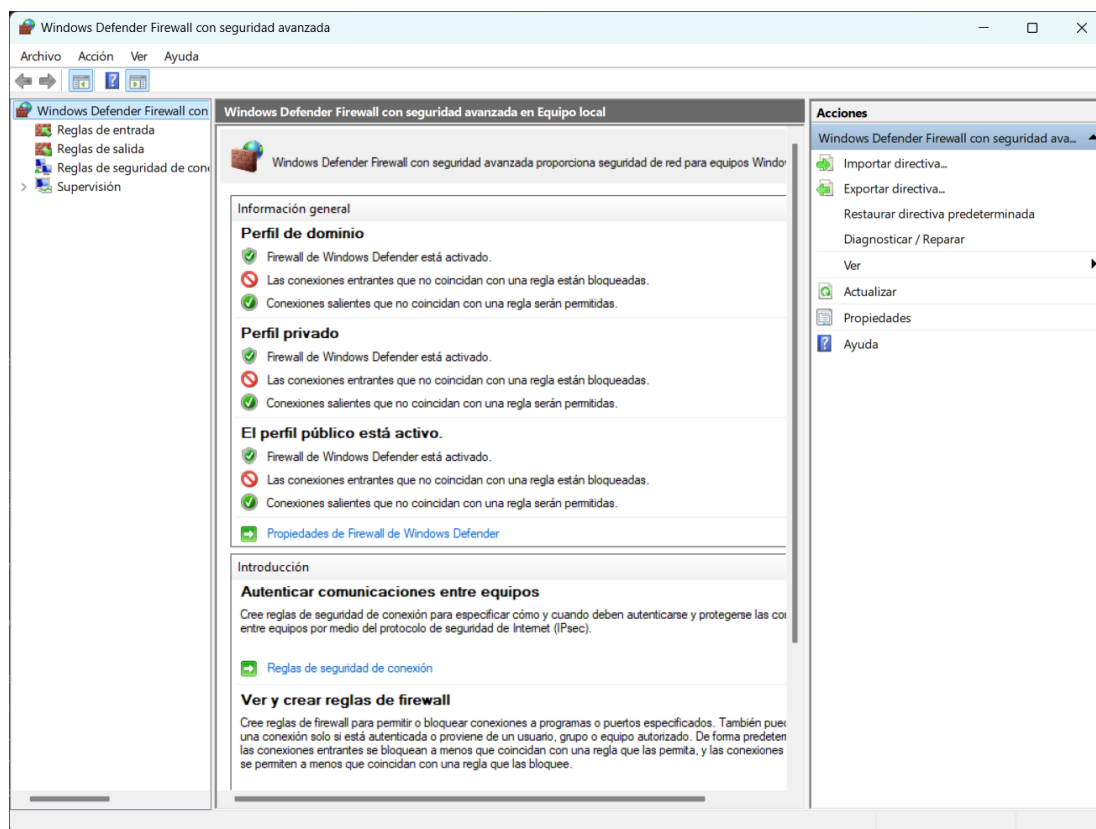


Ilustración 22 Ventana abierta con wf.msc

Paso 2: Revisar perfiles y anotar número de reglas

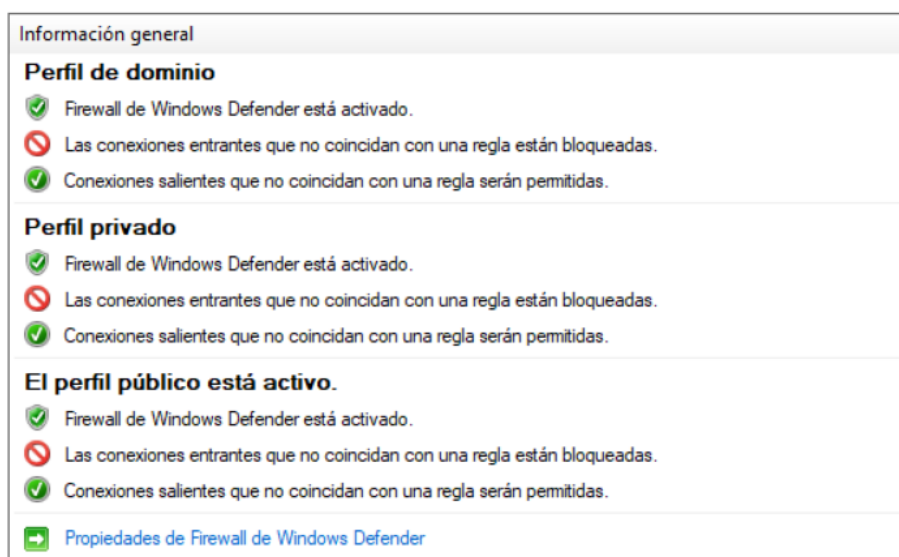


Ilustración 23 Perfiles Activados

Para el conteo de las reglas, ejecutamos comandos en powershell para un conteo más preciso.

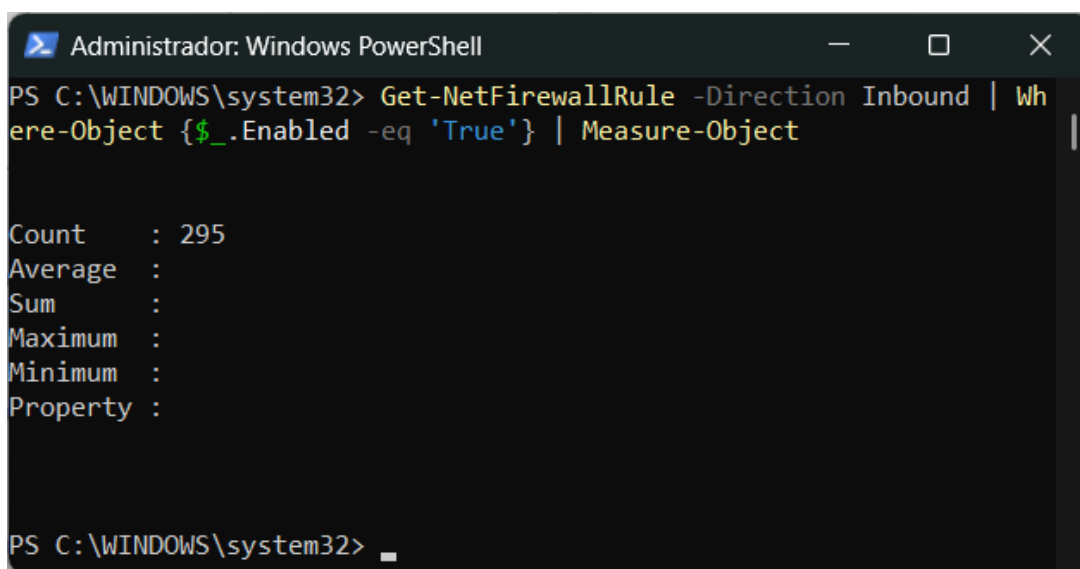


Ilustración 24 Conteo de reglas totales

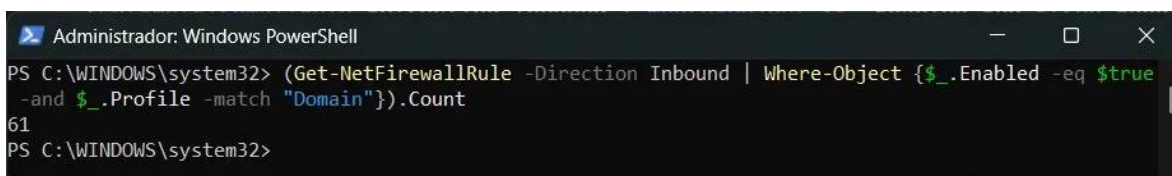


Ilustración 25 Conteo de reglas de dominio


```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> (Get-NetFirewallRule -Direction Inbound | Where-Object {$_.Enabled -eq $true
-and $_.Profile -match "Private"}).Count
81
PS C:\WINDOWS\system32>
```

Ilustración 26 Conteo de reglas privadas

```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> (Get-NetFirewallRule -Direction Inbound | Where-Object {$_.Enabled -eq $true
-and $_.Profile -match "Public"}).Count
112
PS C:\WINDOWS\system32>
```

Ilustración 27 Conteo de reglas públicas

Entonces tenemos:

- Domain Profile Inbound Rules: 61
- Private Profile Inbound Rules: 81
- Public Profile Inbound Rules: 112

Paso 3: Crear regla personalizada - Bloquear Telnet

Este comando crea una nueva regla que bloquea el puerto 23 (Telnet).

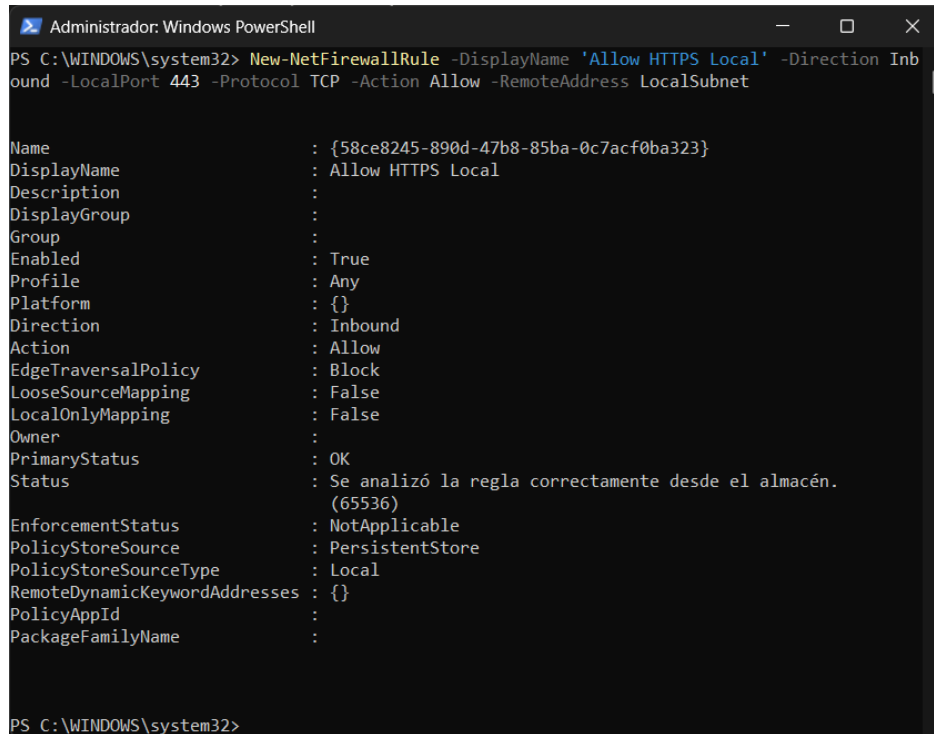
```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> New-NetFirewallRule -DisplayName 'Block Telnet' -Direction Inbound
-LocalPort 23 -Protocol TCP -Action Block

Name                           : {f357b63b-61e3-439f-bdc6-d3da1b176a6b}
DisplayName                     : Block Telnet
Description                     :
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                       : {}
Direction                      : Inbound
Action                         : Block
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping                : False
Owner                           :
PrimaryStatus                   : OK
Status                         : Se analizó la regla correctamente desde el almacén. (65536)
EnforcementStatus               : NotApplicable
PolicyStoreSource               : PersistentStore
PolicyStoreSourceType           : Local
RemoteDynamicKeywordAddresses  : {}
PolicyAppId                     :
PackageFamilyName               :
```

Ilustración 28 Comando para la creación de la regla de bloqueo de telnet

Paso 4: Crear regla personalizada - Permitir HTTPS local

Este comando crea una regla que permite tráfico HTTPS (puerto 443) solo desde la subred local.

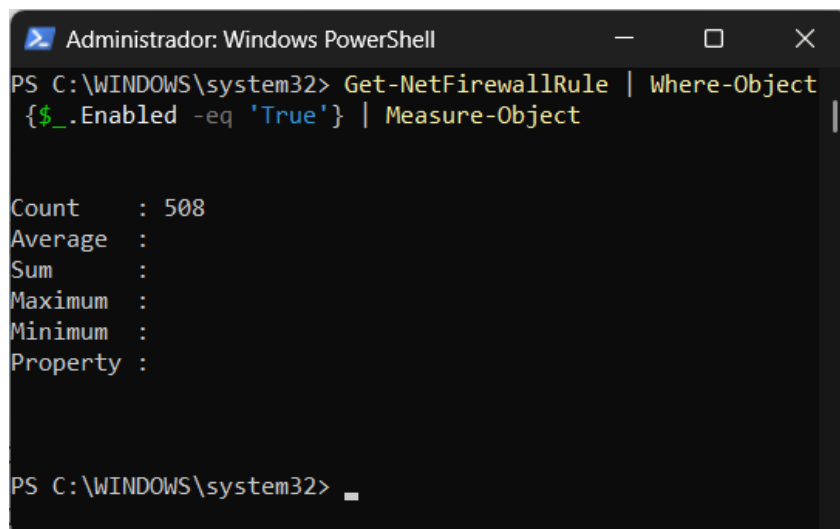


```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> New-NetFirewallRule -DisplayName 'Allow HTTPS Local' -Direction Inbound -LocalPort 443 -Protocol TCP -Action Allow -RemoteAddress LocalSubnet

Name                           : {58ce8245-890d-47b8-85ba-0c7acf0ba323}
DisplayName                     : Allow HTTPS Local
Description                     :
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                       : {}
Direction                      : Inbound
Action                         : Allow
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping                : False
Owner                           :
PrimaryStatus                   : OK
Status                         : Se analizó la regla correctamente desde el almacén.
                                (65536)
EnforcementStatus               : NotApplicable
PolicyStoreSource               : PersistentStore
PolicyStoreSourceType           : Local
RemoteDynamicKeywordAddresses  : {}
PolicyAppId                     :
PackageFamilyName               :
```

Ilustración 29 Comando para regla personalizada de HTTPS Local

Paso 5: Verificar todas las reglas habilitadas



```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> Get-NetFirewallRule | Where-Object {$_.Enabled -eq 'True'} | Measure-Object

Count      : 508
Average    :
Sum         :
Maximum    :
Minimum    :
Property   :
```

Ilustración 30 Número e reglas aumentado

Paso 6: Exportar la configuración

```
Administrador: Windows PowerShell
PS C:\WINDOWS\system32> netsh advfirewall export C:\firewall-backup.wfw
Aceptar
PS C:\WINDOWS\system32>
```

Ilustración 31 Resultado de exportación de configuración

Laboratorio 6 - Políticas de Contraseñas, Bloqueo y Usuarios

Objetivo: Configurar políticas de contraseñas fuertes, bloqueo de cuentas y derechos de usuario.

Paso 1: Abrir Local Security Policy y configurar Password Policy

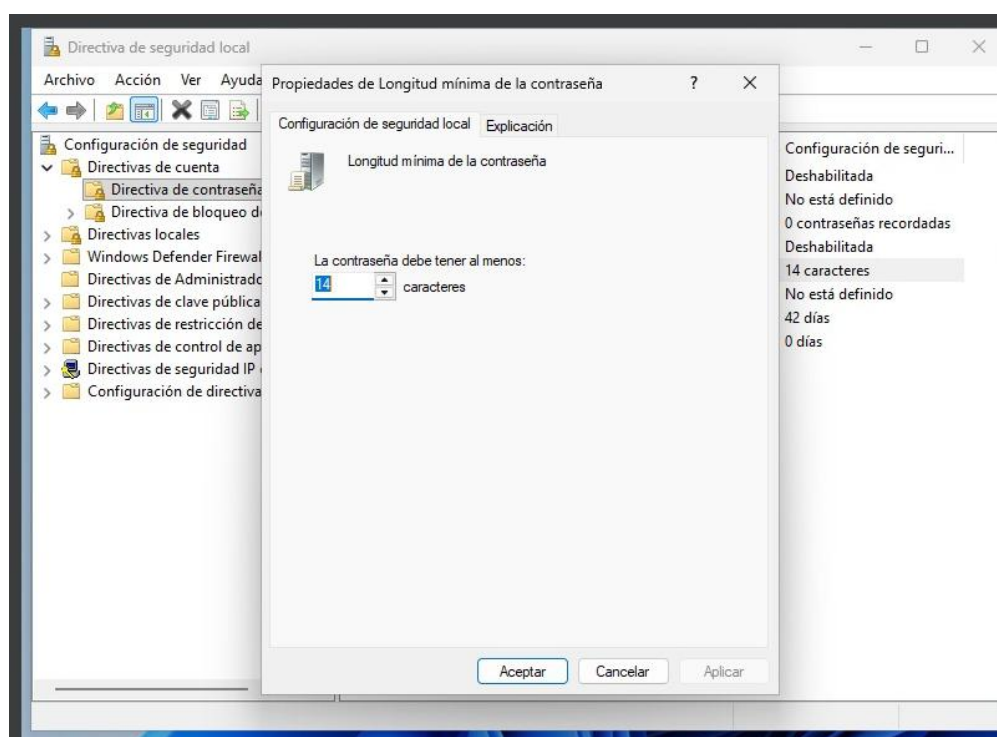


Ilustración 32 Contraseña de 14 caracteres

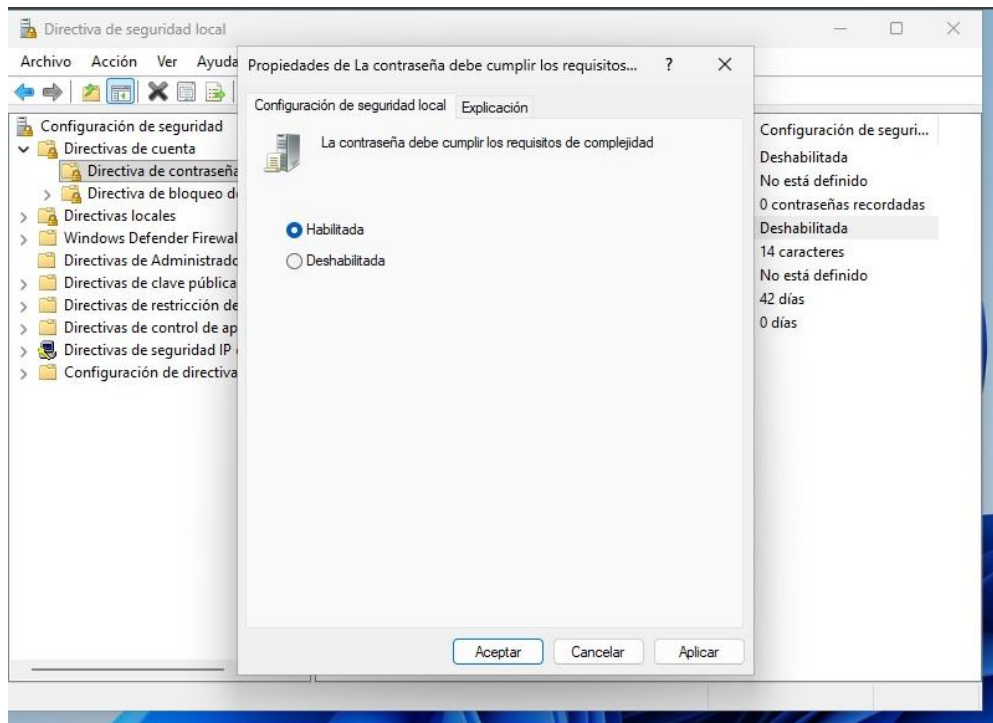


Ilustración 33 La contraseña cumple con niveles de complejidad

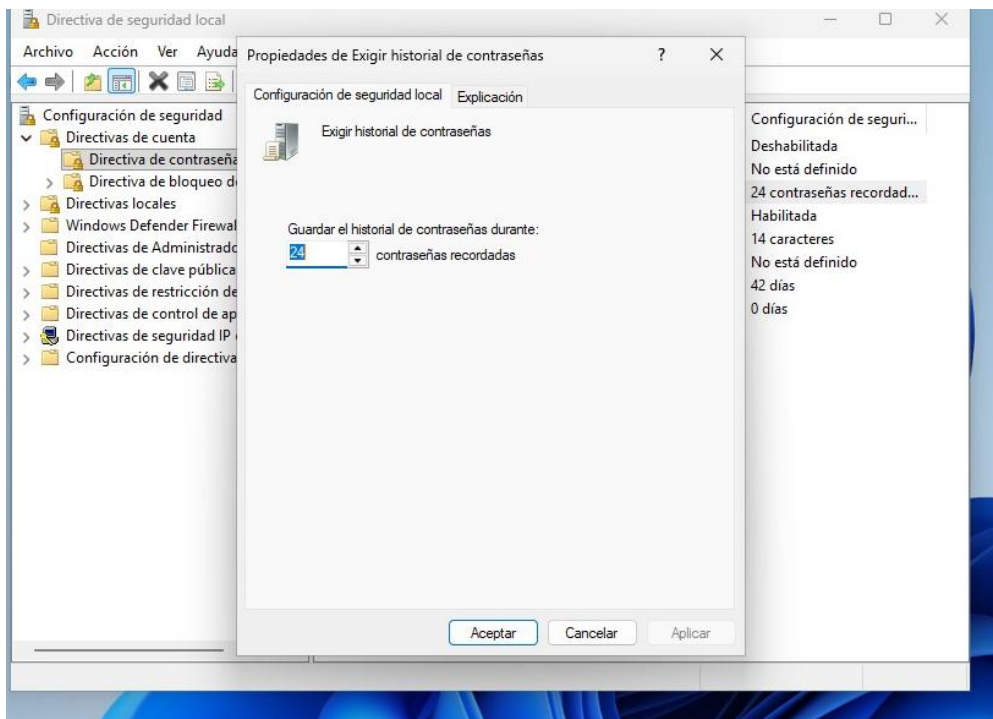


Ilustración 34 Enforce password history

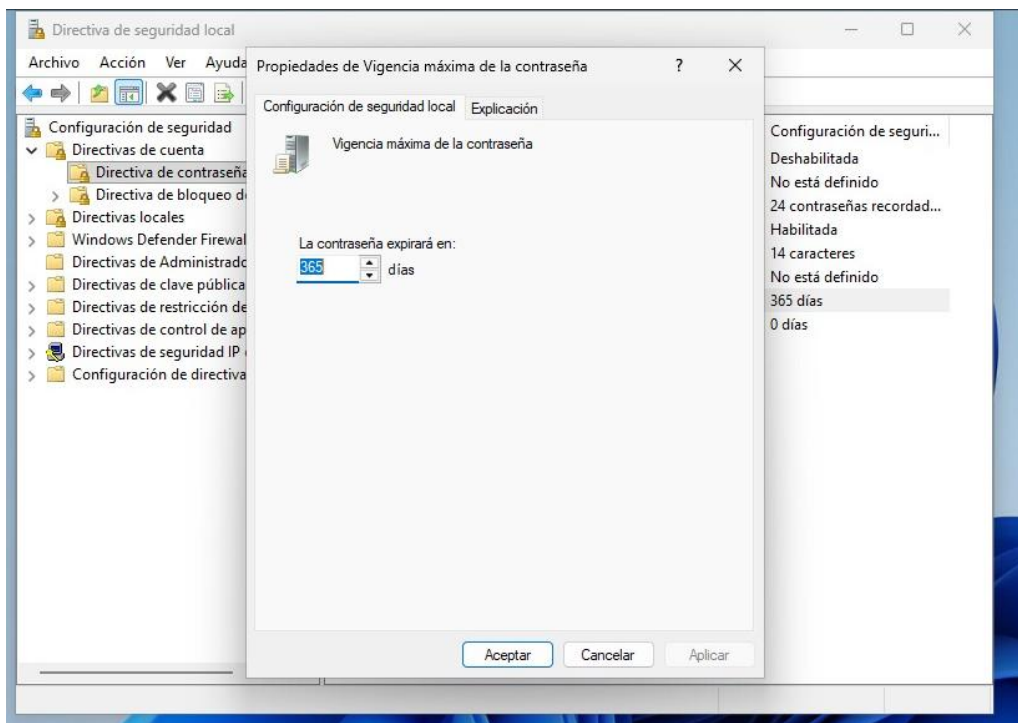


Ilustración 35 Maximum password age

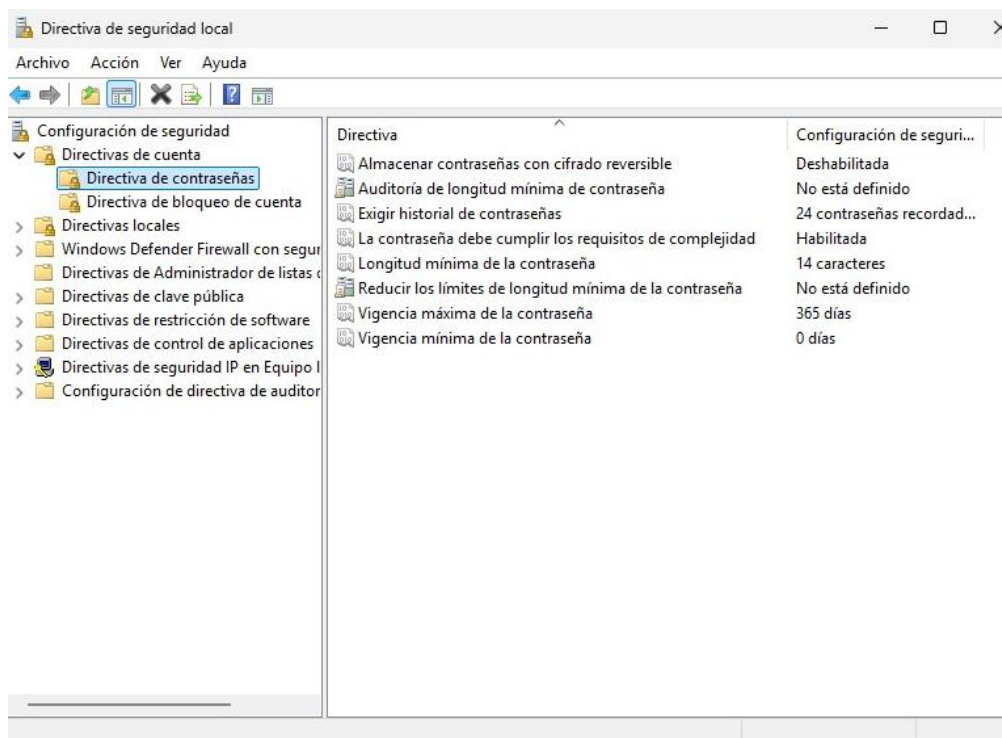


Ilustración 36 Comprobación de la configuración

Paso 3: Configurar Account Lockout Policy

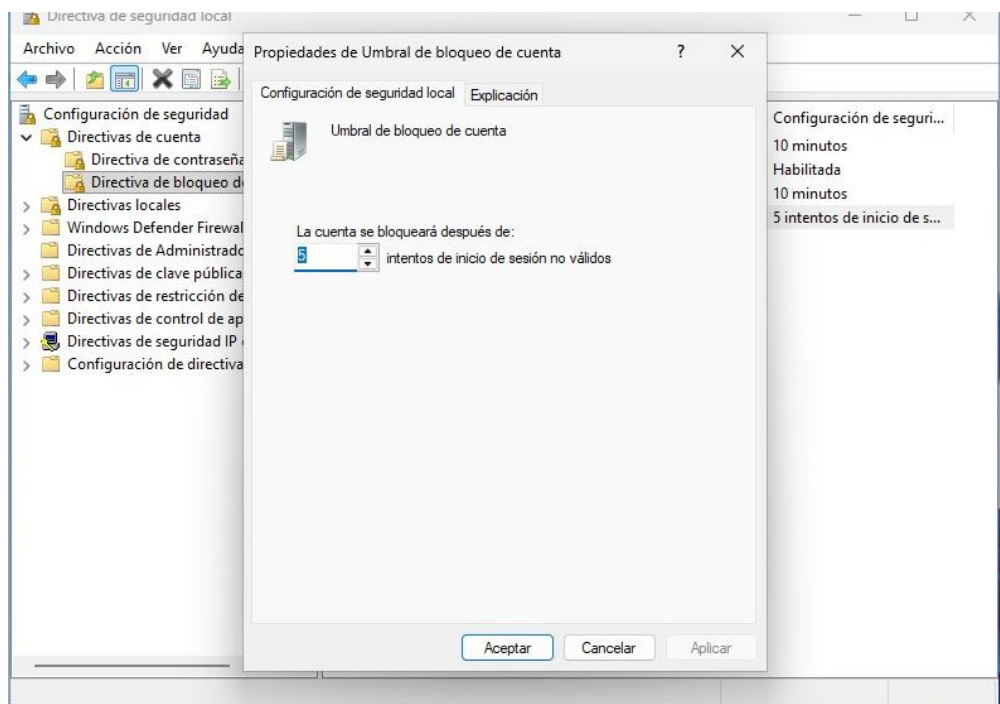


Ilustración 37 Threshold de 5 intentos

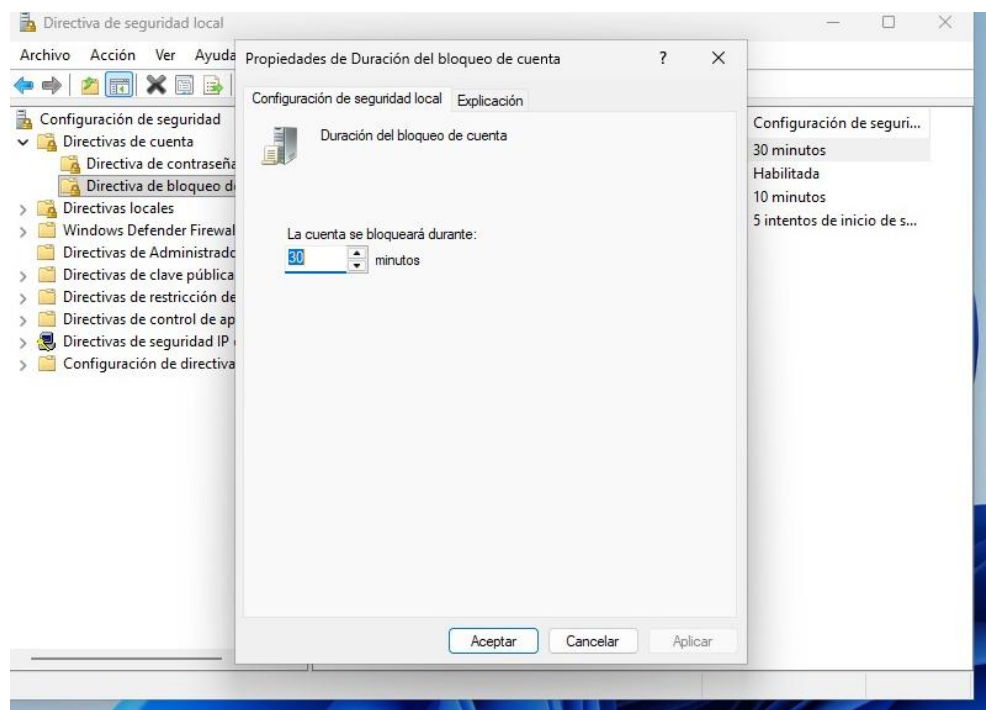


Ilustración 38 Account lockdown duration 30 min

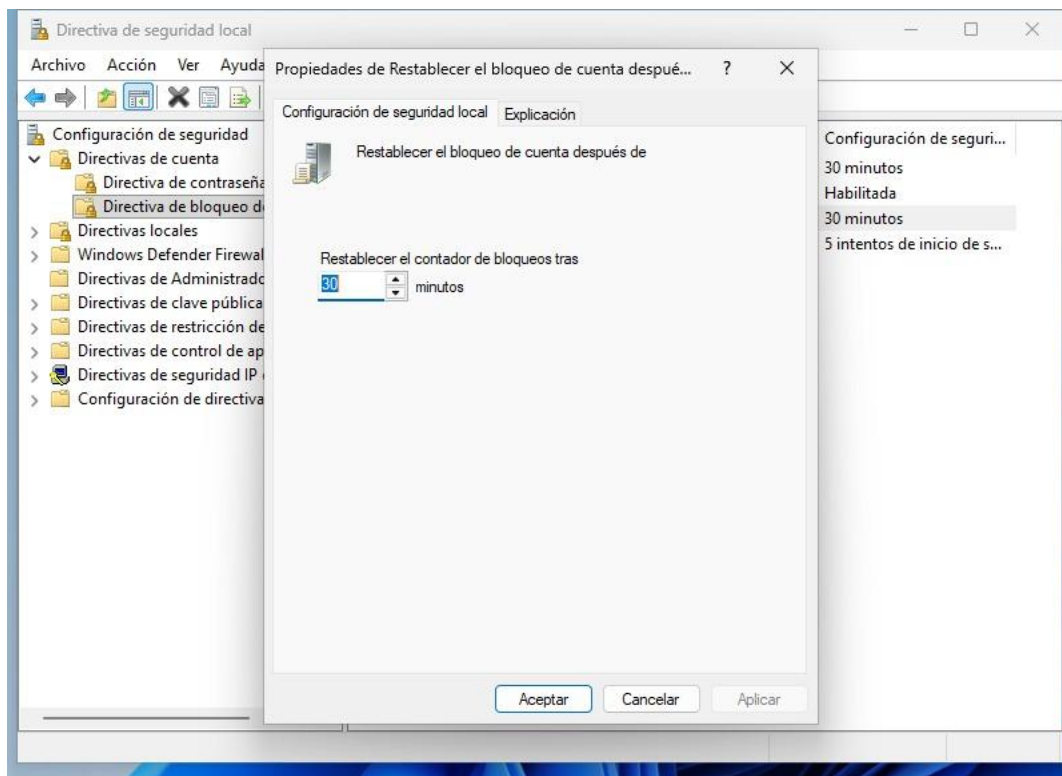


Ilustración 39 Reestablecer el contador de bloqueos

Laboratorio 7 - Habilitación y Configuración de Sysmon Nativo

Objetivo: Habilitar Sysmon nativo (Build 26200.7922+) y capturar eventos de seguridad avanzados.

Paso 1. Habilitar Sysmon e instalarlo con configuración por defecto

```
PS C:\WINDOWS\system32> Dism /Online /Enable-Feature /FeatureName:Sysmon
Herramienta Administración y mantenimiento de imágenes de implementación
Versión: 10.0.26100.5074

Versión de imagen: 10.0.26200.8246

Habilitando características
[=====100.0%=====]
La operación se completó correctamente.
PS C:\WINDOWS\system32> Sysmon -i
Installing Sysmon.
Sysmon installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon..
Sysmon started.
PS C:\WINDOWS\system32>
```

Ilustración 40 Comandos para habilitar e instalar Sysmon

Paso 2: Generar actividad de prueba

```
PS C:\WINDOWS\system32> powershell -Command "Write-Host 'Test'"
Test
PS C:\WINDOWS\system32> eventvwr.msc
```

Ilustración 41 Actividad de prueba generada y abrir Event Viewer

Paso 3. Buscar Event IDs específicos

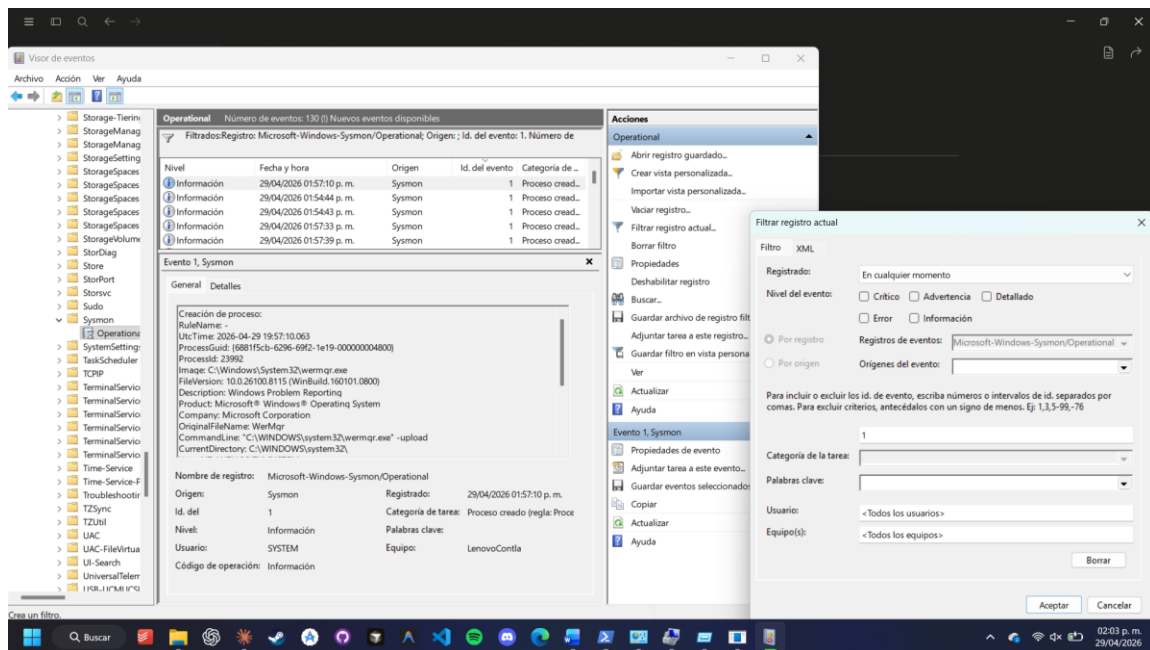


Ilustración 42 Conteo de 53 eventos de id 1

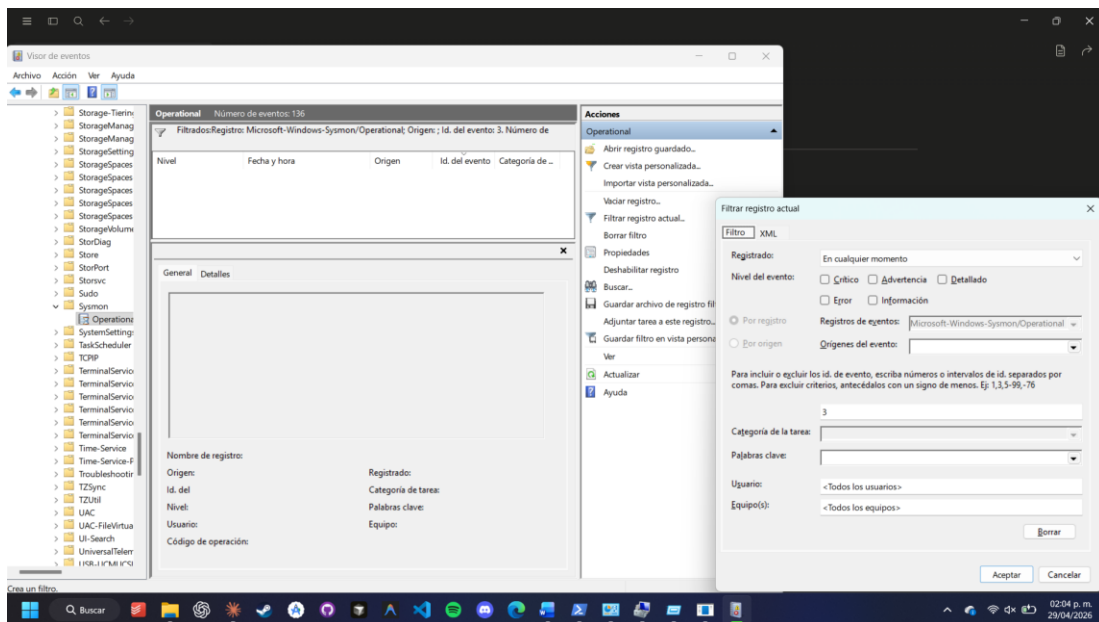


Ilustración 43 Conteo de 0 eventos de id 3

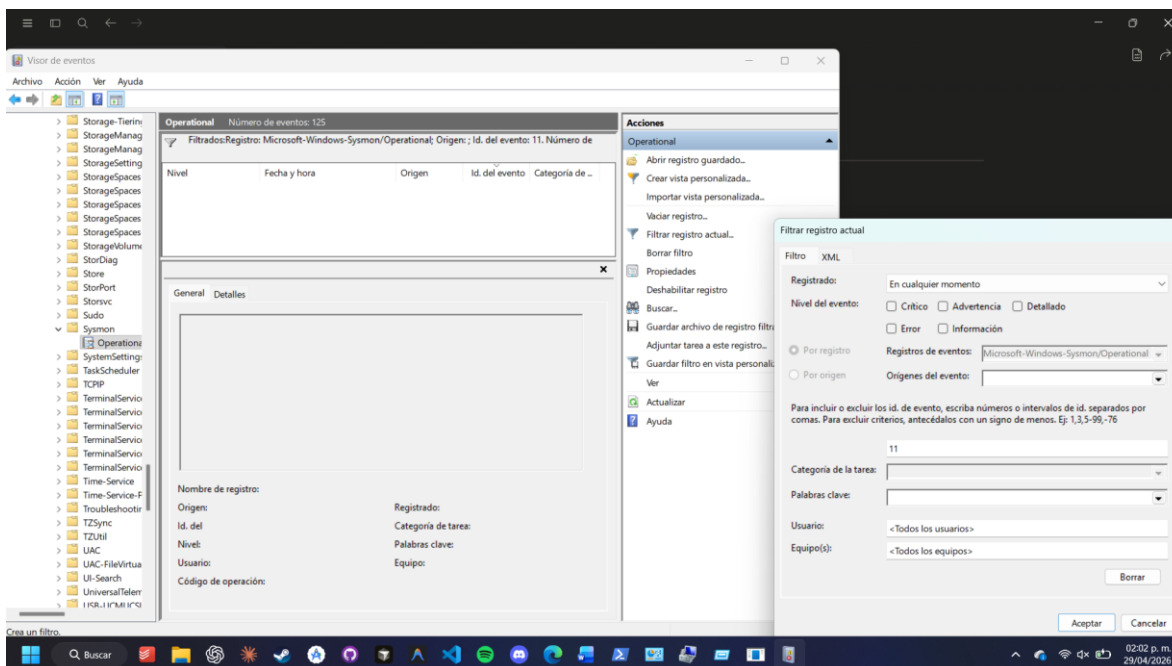


Ilustración 44 Conteo de 0 eventos de id 11

Laboratorio 8 - Controlled Folder Access y Simulación Anti-Ransomware

Objetivo: Habilitar Controlled Folder Access y simular protección contra ransomware.

Controlled Folder Access protege contra ransomware bloqueando intentos de cifrar archivos en carpetas críticas del usuario (Documentos, Escritorio, Imágenes, Descargas). La funcionalidad se puede personalizar para permitir aplicaciones confiables que sí necesiten escribir en esas carpetas.

```

Administrador: Windows PowerShell
PS C:\WINDOWS\system32> Set-MpPreference -EnableControlledFolderAccess Enabled
PS C:\WINDOWS\system32> (Get-MpPreference).ControlledFolderAccessProtectedFolders
PS C:\WINDOWS\system32> "This is a test file" | Out-File -FilePath "$env:USERPROFILE\Desktop\test_ransomware.txt" -Force
PS C:\WINDOWS\system32> Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Windows Defender/Operational'; ID=1123} | Select-Object -First 5

ProviderName: Microsoft-Windows-Windows Defender

TimeCreated          Id LevelDisplayName Message
-----
29/04/2026 02:10:05 p. m. 1123 Advertencia El acceso controla...

PS C:\WINDOWS\system32> Add-MpPreference -ControlledFolderAccessAllowedApplications "C:\Program Files\MyApp\app.exe"
PS C:\WINDOWS\system32>

```

Ilustración 45 Habilitación, Prueba y Auditoría de Controlled Folder Access

Se habilitó Controlled Folder Access y generamos un archivo de prueba para simular ransomware. El sistema bloqueó exitosamente el intento, registrando el evento ID 1123 en auditoría (timestamp 29/04/2026 02:10:05). Posteriormente, agregamos una aplicación confiable a la lista blanca. Confirmamos que Controlled Folder Access protege efectivamente contra intentos de cifrado de archivos mientras permite aplicaciones autorizadas.

Laboratorio 9 - Auditoría Avanzada de Eventos de Seguridad

Objetivo: Configurar Advanced Audit Policy y analizar eventos de seguridad.

Paso 1: Abrir Group Policy y habilitar auditoría para:

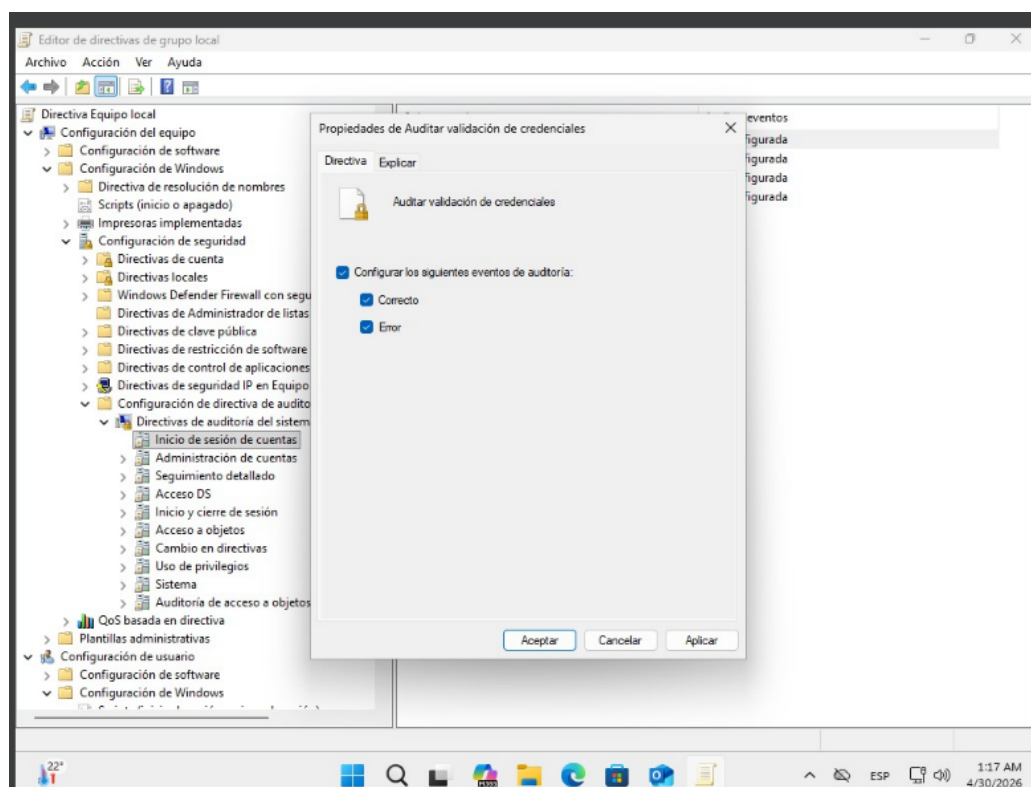


Ilustración 46 Validación de Credenciales

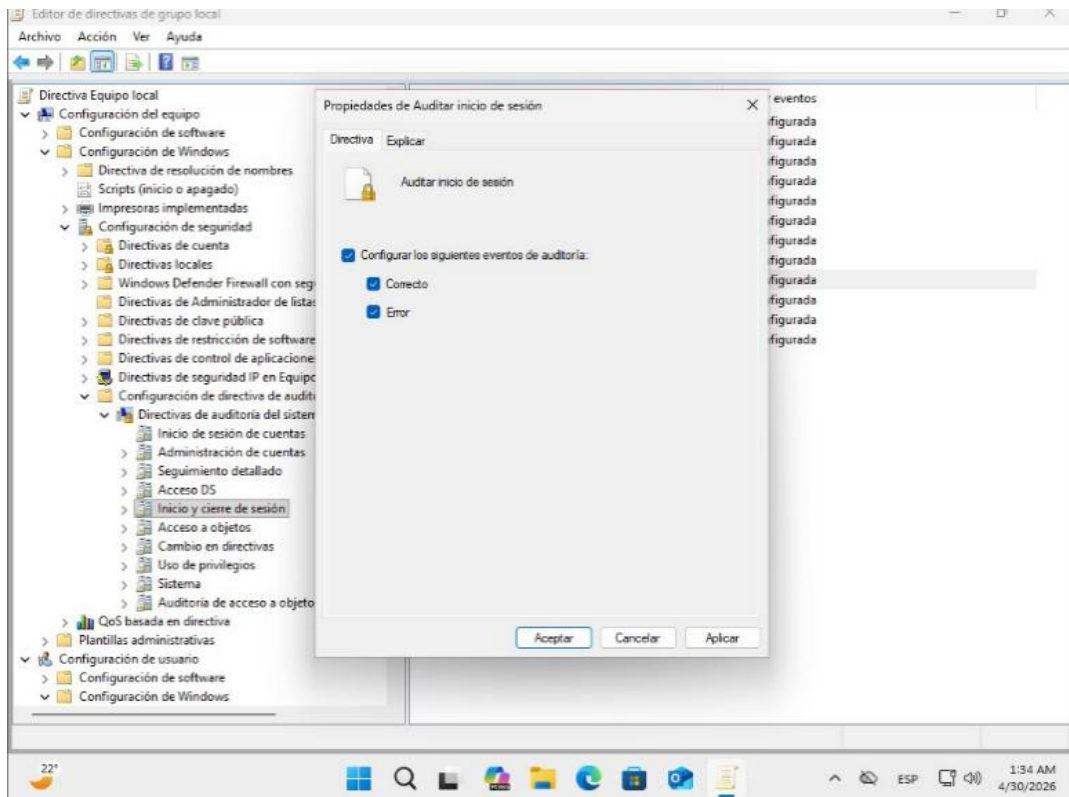


Ilustración 47 Inicio de sesión

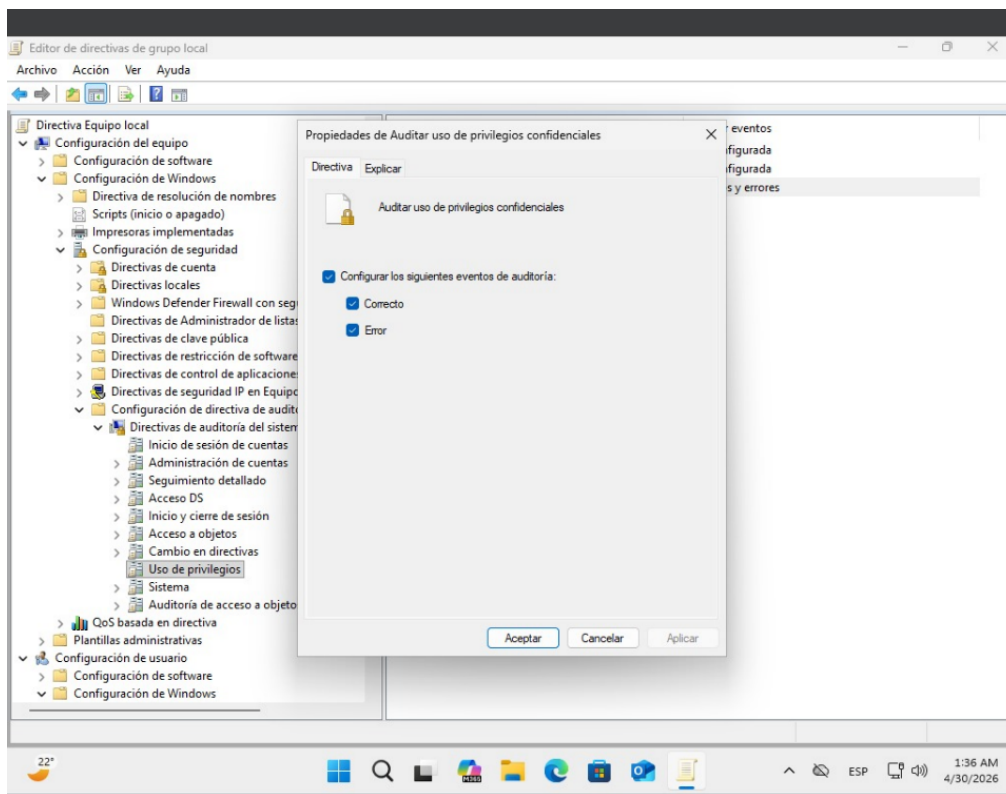


Ilustración 48 Privilegios confidenciales

Paso 4: Generar eventos de prueba

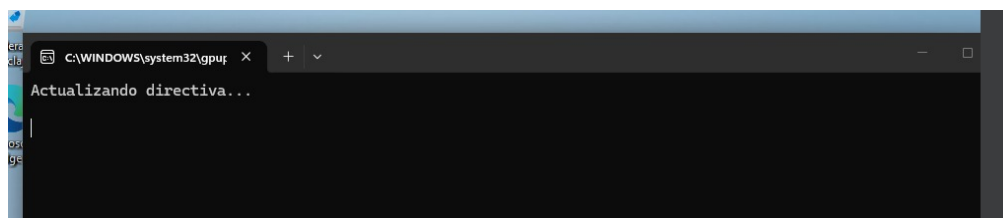


Ilustración 49 Forzando actualización de directiva

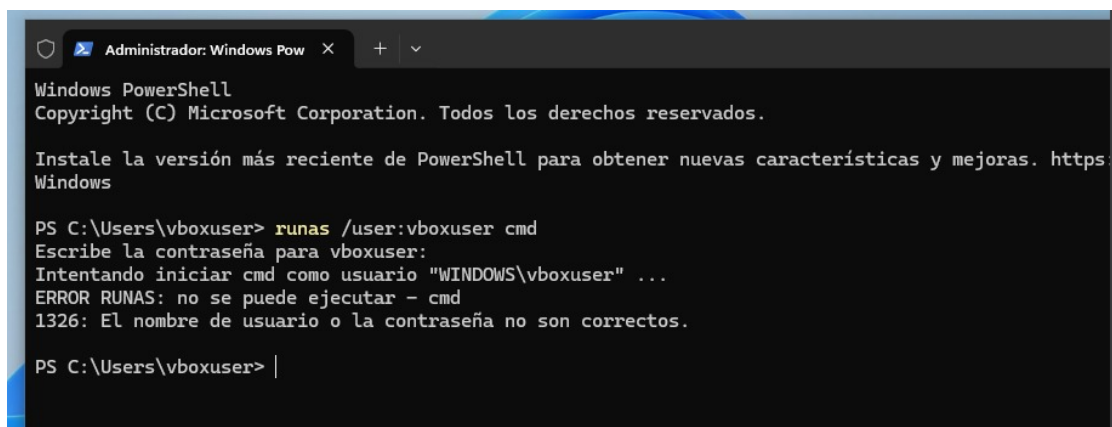


Ilustración 50 Inicio de sesión fallido

Paso 5: Consultar eventos de seguridad

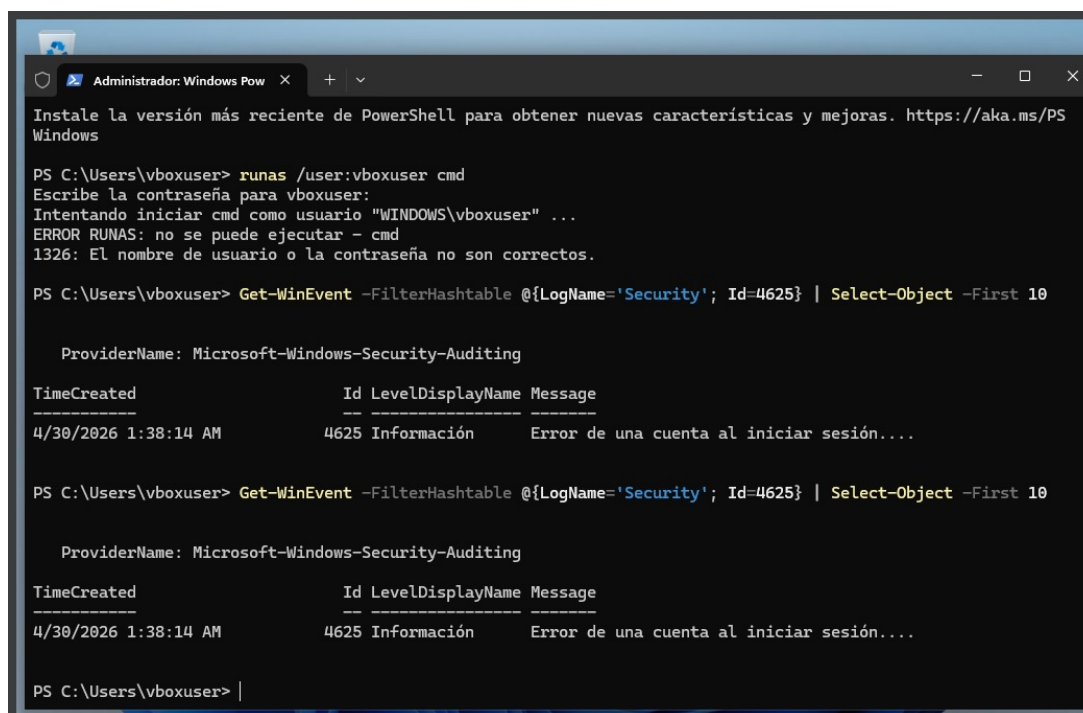


Ilustración 51 Visualización de logs fallidos

Laboratorio 10 - Windows Sandbox e Investigación de Software Sospechoso

Objetivo: Habilitar Windows Sandbox, ejecutar EICAR test y verificar aislamiento completo.

Paso 1: Habilitar Windows Sandbox

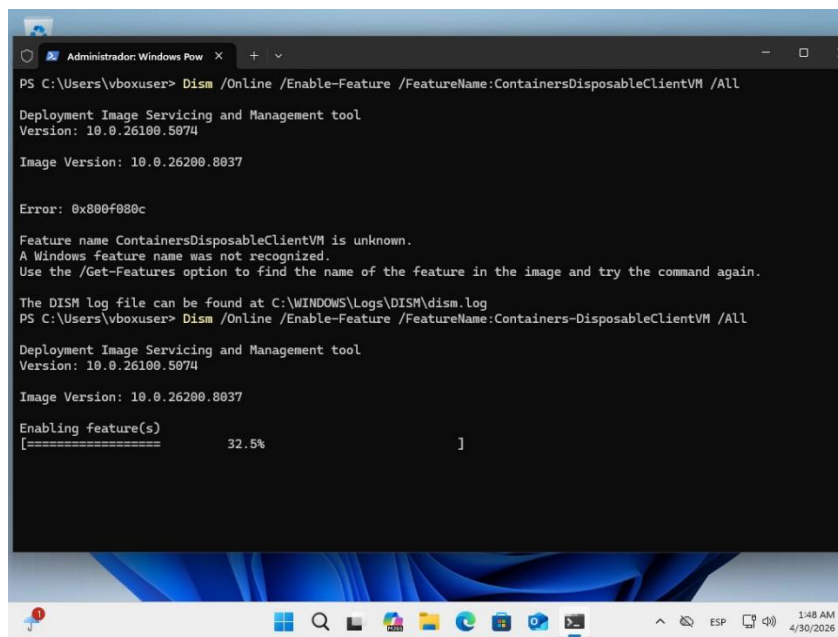


Ilustración 52 Habilitar Windows Sandbox

Paso 2: Abrir Windows Sandbox



Ilustración 53 Fallo de equipo por sandbox



Ilustración 54 Fin del intento

Windows Sandbox no pudo habilitarse debido a que el entorno es una máquina virtual en VirtualBox, la cual no soporta la virtualización anidada necesaria para Hyper-V. Se intentó habilitar mediante DISM y mediante Características de Windows, ambos sin éxito.

Conclusión

Los diez laboratorios no son independientes. HardeningKitty audita contra CIS Benchmarks, pero sin ASR, Sysmon y Controlled Folder Access ese diagnóstico no sirve de mucho. Tres prácticas no corrieron por Windows 11 Home: BitLocker, Credential Guard y Sandbox. No es un detalle técnico menor; en entornos reales las decisiones de licenciamiento tienen consecuencias directas en qué tan expuesto queda el sistema. ASR fue lo que más me cambió la perspectiva. Siempre asumí que Defender era un antivirus con mejoras de marketing. Que las reglas operen sobre comportamientos y no firmas es otra lógica completamente. Sysmon capturó 53 eventos de proceso (Event ID 1) en una prueba básica; los logs estándar de Windows no habrían mostrado nada útil ahí. VBS ya estaba activo en la máquina sin que yo tocara nada, Running con HVCI en enforced. Microsoft está construyendo Windows 11 diferente desde abajo, y no es obvio hasta que lo verificas directamente.

¿Cómo puedo generar un ingreso económico a partir de lo visto en la práctica?

Con lo que cubre esta práctica ya se puede armar un servicio vendible en México. Una auditoría de Windows con HardeningKitty, reporte de hallazgos y tres o cuatro remediaciones concretas se cobra entre \$8,000 y \$15,000 MXN por proyecto. El cliente más fácil al inicio es la PYME que necesita cumplir algún requisito de seguridad pero no tiene área de TI. No piden certificación; piden que alguien sepa qué revisar y cómo explicarlo.

En empleo formal, analista de seguridad Jr. en CDMX parte de \$15,000 MXN y sube a \$35,000 en fintech o telecom. Los roles SOC buscan gente que entienda Sysmon y auditoría de eventos, y no hay tanta. CompTIA Security+ o la SC-900 de Microsoft ayudan a entrar, pero en entrevistas técnicas el portafolio pesa más que el papel.

Referencias

- [1]. Center for Internet Security. (2025). CIS Benchmark for Windows 11 Enterprise v4.0.0. <https://www.cisecurity.org/>
- [2]. Microsoft. (2026). Security Baselines for Windows 11 - v2602. <https://docs.microsoft.com/en-us/windows/security/threat-protection/windows-security-baselines>
- [3]. HardeningKitty Project. (2026). PowerShell Auditing Tool for CIS Benchmarks and Microsoft Security Baselines. GitHub: 0x6d69636b/windows_hardening
- [4]. Microsoft. (2026). Microsoft Defender Antivirus. Attack Surface Reduction Rules. <https://docs.microsoft.com/en-us/windows/security/threat-protection/microsoft-defender-atp/attack-surface-reduction>
- [5]. Microsoft. (2026). BitLocker Drive Encryption. <https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-overview>
- [6]. Microsoft. (2026). Virtualization-Based Security (VBS). Credential Guard. <https://docs.microsoft.com/en-us/windows/security/identity-protection/credential-guard/credential-guard-manage>
- [7]. Microsoft. (2026). Sysmon - System Activity Monitor. <https://docs.microsoft.com/en-us/sysinternals/downloads/sysmon>
- [8]. Microsoft. (2026). Windows Defender Firewall with Advanced Security. <https://docs.microsoft.com/en-us/windows/security/threat-protection/windows-firewall/windows-firewall-with-advanced-security>
- [9]. Microsoft. (2026). Windows Sandbox. <https://docs.microsoft.com/en-us/windows/security/threat-protection/windows-sandbox/windows-sandbox-overview>
- [10]. European Institute for Computer Antivirus Research (EICAR). (2021). EICAR Test File. <https://www.eicar.org/>